

一篇关于WLAN中隐私、随机化MAC地址以及其影响的教程

Domenico Ficara , Rosario G. Garroppo , and Jerome Henrym

摘要—各种应用场景中基于MAC地址系统的隐私问题，例如智慧城市、智能交通系统和市场营销中用于人员追踪和定位系统，凸显了移动设备制造商实施随机化和变更MAC地址（RCM）技术作为应对设备识别挑战的必要性。面对多样化的RCM实现所带来的挑战，IEEE通过802.11aq任务组（TG）对RCM进行了标准化工作。然而，RCM的实施虽然解决了某些问题，但可能会影响原本设计时假设MAC地址静态不变的服务，这些服务跨越了第2层和更高层。为了解决这些挑战，IEEE成立了802.11bh任务组，专注于定义新的设备识别方法，特别是那些需要预关联识别的第2层服务。与此同时，IETF启动了“网络和应用服务中的MAC地址设备识别”（MADINAS）工作组，研究RCM对包括动态主机配置协议（DHCP）在内的上层服务的影响。此外，为了对抗RCM防御机制，去随机化技术也应运而生。这些技术的探索表明，WLAN需要一个更广泛的隐私增强框架，而不仅仅是简单的MAC地址随机化。这些发现促使了802.11bi任务组的成立，该任务组旨在编制一份潜在隐私漏洞和更加私密的IEEE 802.11标准前提条件的详尽列表。

在此背景下，本教程旨在提供启动RCM背后的动机以及对其实施多年来演变的见解，并阐明了RCM对网络过程和服务的影响。此外，教程还深入探讨了802.11bh、802.11bi和MADINAS领域最近取得的进展，提供了这些小组初期工作的详细分析，并概述了相关研究挑战。教程的目标是激励研究社区探索创新的方法和解决方案，为通过标准化倡议提升WLAN隐私性的持续努力做出贡献。

Index Terms—802.11bh,802.11bi,RCM,privacy..

I. 引言

“隐私”是一个多面的概念，在不同的情境中具有多种含义，通常以领域特定的方式（例如，法规、社会学、人类学等）定义。因此，对于隐私的任何探讨都可能会引发无尽的讨论，直到为特定领域达成一个清晰且有界限的定义。

在网络通信领域中，也有这种复杂性。幸运的是，随着2000年代和2010年代期间隐私问题在公共话语中的关注度不断提高，像国际标准化组织（ISO）[?]和电气与电子工程师协会（IEEE）[2] 等组织，提供了在网络背景下细化隐私概念的定义。ISO和IEEE都将隐私

定义为“公平且授权的”处理个人可识别信息（PII）。正式而言，PII包括任何直接或间接标识个人的数据，或者从中可以推导出个人身份或联系信息的数据。用更简单的术语来说，PII可以是直接标识符（例如，通过网络明文传输的个人姓名），也可以是本身不直接标识个人但当与个人关联时成为标识符的值。例如，个人平板电脑的独特MAC地址可能不会明确显示所有者的姓名，但如果观察者能够将MAC地址与平板电脑的所有者联系起来，则可以通过观察到相关联的MAC地址来推断所有者出现在某个房间内。因此，MAC地址也可以被视为PII，除此之外还有其他潜在的问题。设备传输的其他元素也可能同样符合PII的条件。

IEEE [2] 通过引入“个人相关信息”（Personally Correlated Information, PCI）的概念扩展了隐私讨论。PCI指的是通过观察与特定个体或小团体相关的活动或事件（如通信）而收集的数据。例如，如果一个个人平板电脑作为房间中唯一的设备，以可识别且连贯的顺序传输一系列语音数据包，那么为每个数据包使用新的MAC地址变得无关紧要。仅仅通过观察这些语音数据包的序列就足以推断出所观察到的平板电脑仍然是活动的来源，并可以将该活动与平板电脑的所有者关联起来。PCI通常存在于传输机制中，隐藏在信息或功能元素、干扰种子、信标的位置或时间等之中。这些元素以可预测的方式重复或显示出独特的结构，随着时间的推移逐渐缩小来源范围，最终识别出单个设备或一组设备。

隐私暴露的程度显著受到网络通信设备背后实体的影响。IEEE将设备分类为两类：

- 个人设备：与个人或用户组（如家庭单位）关联的设备，例如个人手机或家用Wi-Fi接入点（AP）。
- 共享设备：由大量人群使用的设备，使得难以轻易识别个别用户或特定用户组。例子包括仓库中的工作平板电脑、企业分发交换机或大型机场中的

的Wi-Fi接入点（AP）。

隐私问题，尤其是在个人设备通信可以被观察的情况下，自然主要关注于第一类设备。当个人设备连接到观察者可访问的有线网络时，设备便可能被监听。在通信使用无线电波的情况下，监听则变得更加简单，因为任何在传输信号范围内的窃听者都可以尝试在传输中找到PII或PCI。在2000年代末，智能手机和平板电脑逐渐主导无线领域，隐私问题开始在全球范围内出现，这使得隐私更加成为个人设备制造商日益关注的问题。制造商们致力于减少明显的PII泄露。随后，几家厂商逐渐认识到RCM方案用以减轻PII暴露的有效性。

RCM的实施并非没有后果，它显著影响了其他网络组件准确识别特定消息预期源或目的地的能力，从而导致潜在的通信中断风险。因此，IETF和IEEE内部设立了多个制定规则并提供指导的小组，以在增强无线通信中的隐私保护能力和通过确保可靠识别设备来维持通信稳定性之间取得平衡。

A. 贡献与文章结构

IETF和IEEE内部的新小组已经起草了文件，描述了Wi-Fi网络（802.11bi [3]）中与隐私问题相关的挑战，并确定了需要修订第2层服务（802.11bh [4]）和更上层服务（MADINAS [5]）以应对RCM激活后所带来问题。尽管开发过程尚未完成，且在最终确定前仍有许多开放性问题的需要解决，IEEE任务组（TG）和IETF工作组（WG）讨论的一系列Wi-Fi隐私问题仍可鼓励学者对解决方案的研究，即使他们并不会直接参与标准化过程。我们对802.11bh任务组内讨论的方法进行总结和分类，以便读者对这他们的研究有一个总体了解。我们认为现在是更新Wi-Fi隐私问题现状以及正在考虑的潜在解决方案和方法的合适时机。本教程旨在以一种易于大众无线网络社区理解的方式呈现这些内容。

在本篇教程中，作者深入802.11bi和MADINAS活动以实现以下三点：

- 简要描述WLAN的主要隐私问题：这些问题已在标准化工作或研究社区中讨论或提出。
- 概述与RCM对服务和程序的影响相关的议题或注意事项：这些议题可能需要研究社区进一步支持，例如提出克服标准化工作所识别问题的新思路。
- 描述标准化小组正在研究的关键问题。

据作者所知，本工作是首个针对WLAN隐私问题的教程，包含了以减轻最常用解决方案（即RCM）对Wi-

Fi层和上层服务及程序负面影响为目标的标准化工作。此外，本教程总结了致力于定义与Wi-Fi隐私增强相关的关注点及其在802.11bi任务组中考虑的框架的标准化工作。

本文概述了这些研究成果并提出了相关研究挑战。1总结了近期IEEE任务组和IETF工作组为解决WLAN中的隐私问题所做的努力。

本文的组织结构如图2所示。

第二部分：作为基础入门章节，面向不熟悉Wi-Fi技术的读者。其目的是为普通读者提供必要的基础知识，以便理解本文后续讨论的主题。专业读者可以选择跳过这一部分。第三部分：深入探讨无线通信中的隐私暴露问题，特别关注802.11网络。第四部分：介绍并分类与RCM相关的话题，并讨论一些选定的相关工作。详细阐述RCM解决方案以及由802.11aq修正案带来的限制。第五部分：详细描述802.11bh小组为“修复”RCM引入的问题所做的努力。

第六部分：阐述802.11bh工作小组修对RCM导致的隐私问题的修复内容。第七部分：强调802.11bi小组在提升802.11通信隐私方面的工作。第八部分：介绍IETF中MADINAS小组的工作，重点关注与上层服务相关的隐私和RCM挑战。第九部分：总结IEEE任务组和IETF工作组在该领域正在进行的工作所阐明的经验教训和研究挑战。第十部分：结论，总结全文。

II. Wi-Fi网络的背景知识

这部分内容为没有相关知识储备的读者提供了Wi-Fi网络的背景知识，这些知识是本篇教程讨论的问题的基础。

A. 协议架构

IEEE 802 包含了一整套标准，涵盖了局域网（LAN）、个人区域网（PAN）和城域网（MAN）。如图3所示，这些标准对应于开放系统互连（OSI）模型中的数据链路层（DLL）和物理层（PHY）。数据链路层进一步细分为两个子层：逻辑链路控制（LLC）和介质访问控制（MAC）。值得注意的是，广泛采用的IEEE 802标准主要针对LAN场景，特别强调以太网、桥接和虚拟桥接局域网，以及无线局域网。除了MAC和LLC层之外，IEEE 802.1工作组还处理额外的网络问题，开发涵盖架构、链路安全、桥接和管理标准。本文中提到的相关标准包括802.1AE “MAC安全”、802.1X “基于端口的网络访问控制”、

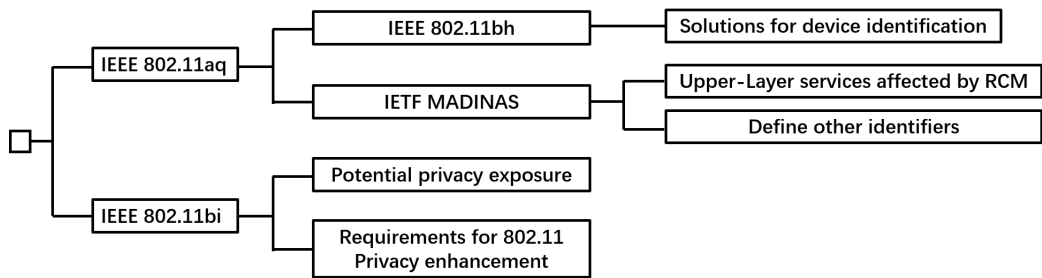


图 1. IEEE TGs 和 IETF WG 在 WLANs 隐私问题上的发展历程

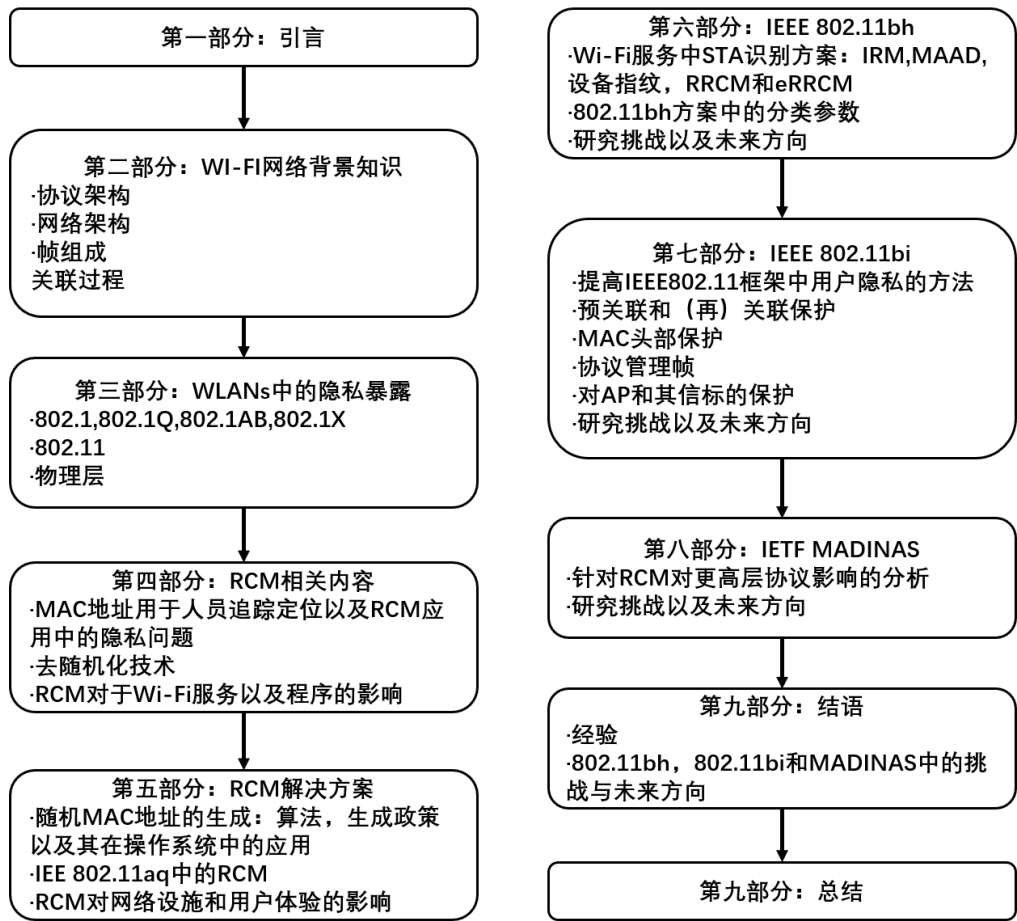


图 2. 文章结构

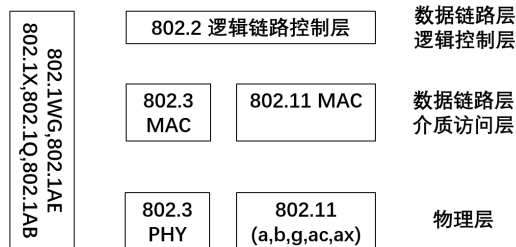


图 3. 从 Wi-Fi 和以太网技术出发的 IEEE 802 局域网通用协议栈

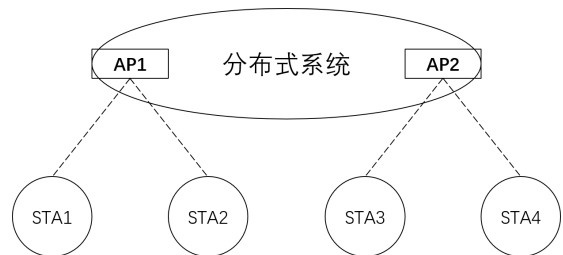


图 4. 从 Wi-Fi 和以太网技术出发的 IEEE 802 局域网通用协议栈

802.1Q “桥接和桥接网络”以及802.1AB “站址和媒体访问控制连接发现”。典型的企事业单位局域网设置整合了以太网（802.3）和Wi-Fi设备（802.11）。逻辑链路控制层通过为数据链路服务用户提供标准化接口发挥着关键作用，这取决于所采用的具体传输技术，比如以太网或Wi-Fi。

B. 网络结构

一个Wi-Fi网络可以在自组织（ad hoc）模式和基础结构（infrastructure）两种模式下工作。本文聚焦于更为常见的基础结构模式，其中站台（stations, STAs）通过接入点（Access Point, AP）访问网络服务。STA与AP组成基本服务集（Basic Service Set, BSS），并通过BSS标识符（BSSID），即AP的MAC地址，进行标识。扩展服务集（Extended Service Set, ESS）由分布式系统（Distribution System, DS）连接的多个BSS组成，整体结构如图4所示。DS保证不同BSS所属STA之间或STA与Wi-Fi网络外部主机之间的Wi-Fi服务的逻辑功能。一个服务集标识符（Service Set Identifier, SSID）用于标识一个Wi-Fi网络。

C. 帧构成

如图5所示，802.11帧头包含四个MAC地址字段，这些字段的解释依赖于帧控制字段中的FromDS和ToDS标志位。当站台（STA）向接入点（AP）发送数据时（FromDS=0且ToDS=1），第一个地址字段包含目标AP的MAC地址，作为接收地址（Receiver Address, RA）。第二个地址字段为STA的源地址（Source Address, SA）和发送地址（Transmitting Address, TA）。第三个地址表示帧的最终目的地址（Destination Address, DA），它可以是BSS/ESS中的另一个STA或者是AP后面的有线网络上的设备。相反，当AP向STA发送数据时（FromDS=1且ToDS=0），第一个地址字段包含STA的地址作为RA，第二个地址字段则包含AP的地址作为TA，而第三个地址字段包含帧的SA。在这种情况下，SA可能是BSS中的另一个STA或者是有线网络上的设备。在这两种场景中，第四个地址字段均未被使用。此字段仅在帧通过分发系统（DS）转发时才发挥作用。在这种情况下，FromDS和ToDS均为1，四个地址字段分别包含RA、TA、DA以及SA。

头部还包含了额外的信息，包括从帧控制字段的类型（Type）和子类型（SubType）字段中得出的帧类

型，以及与接收方在接收到帧并进行解调后相关的其他程序参数。Wi-Fi标准将无线帧分为三大类：数据帧、管理帧和控制帧。数据帧封装了更高级别的数据（例如，IP数据包），管理帧处理网络管理任务（例如，设备连接到AP），而控制帧则调解对共享介质的访问，包括碰撞检测和虚拟载波侦听等功能。这些帧类型进一步细分为不同的子类型；例如，管理帧包括信标（beacon）、探测请求（Probe Request）和去认证（de-authentication）等子类型，而控制帧则包括发送请求（Request to Send, RTS）和发送清除（Clear to Send, CTS）等子类型。

信标帧（beacon frame）由接入点（AP）周期性地传输，在Wi-Fi网络中作为管理帧具有重要意义。它的主要功能是通过SSID宣布网络，并传达一组包含关于网络配置和可用服务的关键信息的信息元素（Information Elements, IEs）。IEs专为管理帧设计，由一个八位字节表示元素的身份（ID），第二个八位字节定义其长度，剩下的部分则携带相关信息。例如，强健安全网络（Robust Secure Network, RSN）IE提供了适用的安全框架的详情；支持的速率（supported rates）则指定了最多八个速率；而EDCA参数集（EDCA Parameter Set）提供了QoS机制正确运行所需的信息。除了信标帧之外，信息元素还存在于如探测请求的其他管理帧中。

通过Wi-Fi无线接口传输的管理信息是以明文形式发送的，缺乏保护。这是Wi-Fi网络一个重大弱点，并已被用于多种类型的攻击[6]、[7]、[8]。2009年，802.11w修正案[9]（已被整合到2012年的标准修订版）引入了加密某些管理帧的选项，建立了受保护的管理帧（Protected Management Frames, PMF）协议。其主要目标是防止AP冒充，即攻击者伪造AP的MAC地址并向受害站台（STA）发送帧，暗中通过不当发起的去认证/去关联攻击（De-authentication/Disassociation Attack）[10]来终止会话。

D. 关联过程

要加入一个网络，STA必须首先发现该网络。发现过程依赖于被动或主动的扫描程序。被动方式：STA在多个Wi-Fi信道上等待接收宣告网络SSID的信标帧。这种方法隐藏了STA的存在，但它需要更多时间。主动方式：STA发送广播探针请求，该消息可能包含之前使用过的网络的SSID。拦截探针请求允许第三方获取

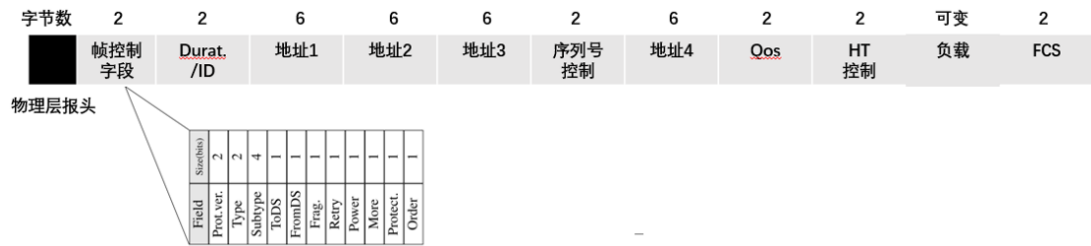


图 5. 802.11标准MAC报头

关于STA和网络的信息，包括STA的存在及其已知网络。这些信息可用于各种攻击，例如恶意AP宣告所需的网络[7]、[8]，以及用于发现用户访问过的位置。服务网络的AP会以单播探针响应（Probe Response）回应STA发出的探针请求。探针响应封装了所有存在于信标中的信息，为STA提供了有关网络能力的详细信息。这使得STA能够有效地理解和适应其在网络环境中的操作。一旦STA建立了一组潜在的AP列表，802.11关联过程便开始如图6所示关联过程。

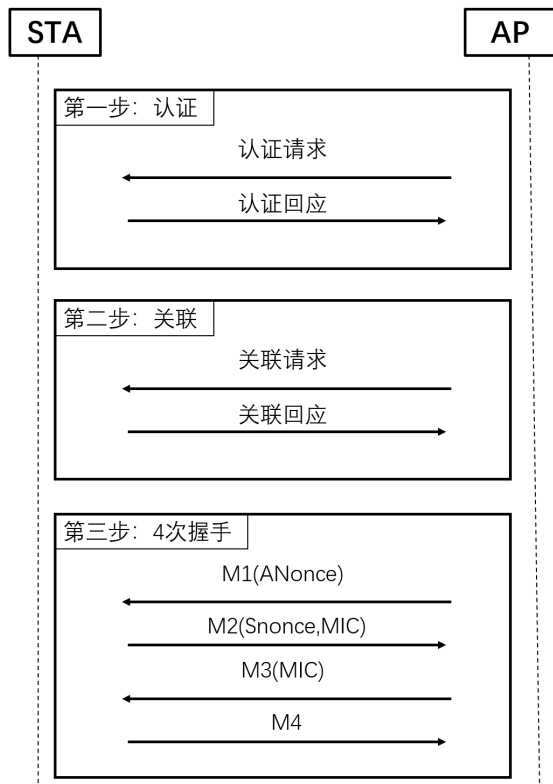


图 6. 关联过程

认证阶段术语“认证”带有安全含义，通常被认为旨在验证STA作为有效802.11设备的合法性。这在802.11最初发布时引发了担忧。因此，在802.11早期阶段，引入了一种称为有线等效隐私（Wired Equivalent

Privacy, WEP）的弱双向认证机制。WEP允许双方确认拥有相同的预共享密钥。然而，由于存在效率低下且存在缺陷的问题，WEP于2007年被弃用。随后，认证阶段回归其原始目的，不再包含WEP机制。

关联阶段的目标是在AP上为STA分配一个关联标识符（唯一的客户端编号），并交换可选参数支持。一个关键信息是网络所采用的安全框架，通过RSN IE（Robust Security Network Information Element）传达。最常见的Wi-Fi安全框架选项包括开放（Open）、Wi-Fi保护访问2（Wi-Fi Protected Access 2, WPA2），以及最新的演进Wi-Fi保护访问3（Wi-Fi Protected Access 3, WPA3）。对于非保护网络（开放），连接在关联阶段完成后即告完成，STA可以开始发送和接收数据。然而，大多数网络实现了WPA2或WPA3中的一种定义模式：个人模式（Personal），适用于家庭和小型办公室网络，无需认证服务器；企业模式（Enterprise），适用于需要认证服务器的企业网络。

四次握手阶段（4-Way Handshake, 4-WHS），其目的是进行双向认证，并定义和安装用于保护STA与AP之间无线链路上单播数据帧的保密性和完整性的成对瞬态密钥（Pairwise Transient Key, PTK）。

起点是一个称为成对主密钥（Pairwise Master Key, PMK）的共同密钥。在个人模式下，PMK是从网络的密码短语获得的；而在企业模式下，则从认证服务器获得。在个人模式中，WPA2和WPA3之间的一个显著区别在于生成PMK的过程。在WPA2中，PMK主要从密码短语和SSID派生而来，这两者都是独立于会话的。这种策略导致了众所周知的字典攻击[11]，这是WPA2-Personal安全框架最严重的弱点之一。相反，在WPA3中，每次会话都会生成一个新的PMK，并通过Simultaneous Authentication of Equals (SAE)交换由两端相互协商确定。SAE使两端能够通过结合密码短语并使用椭圆曲线加密算法来建立共享PMK，从而增强了安全性[12]。PTK通过利用共享

的PMK以及AP和STA的MAC地址，再加上随机生成的值（非ces）来派生。PTK的生成需要基于STA和AP之间交换的四个消息的4-WHS，如图6的第三步所示。

- AP发送AP生成的随机数（ANonce）的消息M1。
- STA生成其自己的随机数（SNonce）并计算出成对瞬时密钥。STA随后发送消息M2给AP，该消息包含SNonce和使用PTK计算的消息完整性代码（Message Integrity Code, MIC）。
- AP使用接收到的SNonce来计算PTK以及接收消息的MIC。如果计算出的MIC与接收到的MIC匹配，则AP成功认证STA。然后，AP发送带有自己MIC的消息M3。
- STA接收到M3后，STA，AP便拥有了新的PTK（即AP向STA的认证）。随后，STA安装PTK并向AP传输消息M4。通知AP密钥已成功安装，并且现在可用于通过Wi-Fi无线接口提供安全服务。

这些消息是数据帧，可以包含密钥数据封装（Key Data Encapsulation, KDE）元素，用于交换加密密钥材料及相关信息，以确保设备之间安全的数据传输和认证。

表I显示了文中使用的缩写的含义。

III. WLANs中的隐私暴露问题

IEEE 802.11 从一开始设计时就旨在促进无线设备之间的通信，这些设备可能表现出不同的选项和功能。然而，这一设计特点使得该协议容易通过功能暴露的过程受到隐私攻击，在此过程中，对手仅通过设备指纹识别就可以获取敏感信息。

要理解 WLAN 中的隐私漏洞问题，有必要通过定义那些一旦被攻破就可能泄露个人身份信息（PII）或支付卡行业信息（PCI）的目标来建立坚实的基础。一些实体已经表现出对从 IEEE 802.11 帧中提取个人身份信息的兴趣，其目的各不相同，包括以下方面：

- 监控：对手可以进行被动跟踪，在网络中悄悄地监控目标位置和连接时间戳。如果从多个网络连接获取了个人身份信息（PII），这种监控形式被称为普遍监控。
- 探测：攻击者可能向特定目标或其接收者发送数据包，以迫使无意中披露个人身份信息。
- 修改：与目标交换的帧可能会被操纵，经过战略性设计后，诱导暴露个人身份信息。

隐私暴露的一个明显关键点在于个人设备的MAC地址，它既可作为源地址（SA）也可作为目的地址（DA）。

表 I
使用的缩略语列表

缩略语	含义
AID	关联标识符
AP	接入点
BPE	基本服务集隐私增强
BSSID	基本服务集标识符
BSS	基本服务集
CPE	客户端隐私增强
DA	目标地址
DHCP	动态主机配置协议
DID	设备标识符
DLL	数据链路层
DS	分布式系统
EAPOL	扩展认证协议
ESS	扩展服务集
HKDF	HMAC-based Extract-and-Expand 密钥派生函数
HS	握手
IE	信息元素
IID	信息元素的身份
IRM	可识别随机MAC
IRMA	IRM-MAC地址
IRMK	IRM密钥
KDE	密钥数据封装
LLC	逻辑链路控制
LLDP	链路层发现协议
MAC	媒体访问控制
M1/2/3/4	四次握手手中的消息1/2/3/4
MAAD	MAC地址指定
MADINAS	网络和应用服务的MAC地址设备标识
MIC	消息完整性代码
NIC	网络接口卡
OUI	组织唯一标识符
OS	操作系统
PCI	个人相关的信息
PCP	优先级控制点
PII	个人可识别信息
PMF	受保护管理帧
PMK	成对主密钥
PMKID	成对主密钥标识符
PTK	成对瞬时密钥
RA	接收地址
RCM	随机化和更改MAC地址
RSSI	接收信号强度指示器
SA	源地址
SAE	同时等价认证
SN	帧序列号
SSID	服务集标识符
STA	站点
TID	流量标识符
TIG	主题兴趣组
TLV	类型-长度-值元素
TPC	发送功率控制
VID	虚拟局域网标识符
WG	工作组
WEP	有线等效隐私
WPA2/3	Wi-Fi受保护访问2/3

一个重要的考虑是，如果目标MAC地址保持为一个通用且静态的标识符，那么就有可能在多个网络中建立关于时间和空间方面的关联。这种关联不仅限于MAC地址仅作为帧内的SA或DA可见的情况；它还包括MAC地址出现在其他网络头部的情形，例如封装的以太网头部、IEEE 802.1Q I-TAG，或是IPv6头部。对任何目标MAC地址的关联可用于追踪其移动位置以

及收集发送到和来自该地址的帧。进一步分析可能涉及识别与个人相关联的MAC地址或确定哪个人与某个MAC地址相关联。目标MAC地址的关联并不总是对隐私构成威胁。个人可以选择为了自身利益而允许这种关联，例如，在网络所有者提供特殊待遇后，明确选择加入关联。然而，未经授权的关联可能会被视为攻击。MAC地址是本文的核心，因为它正是RCM的主要目标。然而，在使用IEEE 802标准进行通信时，还有通过802.11和当帧在网络内部传输时通过其他协议的PII和PCI暴露。

图7总结了与IEEE 802标准领域相关的主要PII/PCI暴露问题，这涵盖了协议栈的两个最低层。

A. 逻辑链路控制子层

1)802.1: IEEE 802.1标准定义了一组功能，这些功能可以扩展帧头部的信息，而这些信息可能被攻击者用来获取PII。一个例子是在某些IEEE 802.1协议中使用封装的MAC地址。例如，802.1Q标准包含了拥塞通知（CN）机制，这涉及到从拥塞点向导致拥塞事件的帧的源MAC地址发送一条CN消息[13]。IEEE 802.1AB是另一个例子，该标准用于有效分发信息给在相同IEEE 802局域网内互联的站点[14]。其主要目的是促进物理拓扑和设备发现管理信息在相关数据库中的积累。此协议使用机箱ID来识别网络系统内的特定机箱，在某些配置下，该ID可能是从设备的MAC地址派生出来的。MAC地址也暴露在IEEE 802.1AE SecTag所使用的安全通道标识符（SCI）中，这有助于为局域网对等协议实体提供透明的网络安全[15]。此外，如果一座桥接器位于面向个人用户的网络边缘，如住宅网关，则它可以被分类为支付卡行业信息（PCI）。与桥接器关联的桥接器地址必须是一个通用地址，并且可能被用来定位主机地址（例如，嵌入在一个流标识符中的地址）。

2)802.1Q: 除了MAC地址之外，还有其他元素可以用作PII。例如，在多个IEEE 802.1Q协议元素中，优先级代码点（PCP）用于标记那些因为具有特殊延迟要求（如语音或视频帧）而需要被优先处理的帧[13]。同样地，IEEE 802.1Q中定义的虚拟局域网标识符（VID）经常被用来分割流量，比如区分发送到不同组织或在组织内扮演不同角色的个人的数据。目标类别（如传输语音或视频流量的端点、组织、角色等）可以根据PCP和VID来识别，要么是直接使用已知配置

（如PCP），要么是在必要时进行关联分析以将VID映射到组织内的不同组织或扮演不同角色的个人。

3)IEEE 802.1AB: IEEE 802.1AB 定义了链路层发现协议（LLDP），用于传达关于一个站点的信息[14]。这些信息被封装在一组类型-长度-值元素（TLVs）中，包括诸如网络地址（主要是IP或MAC地址）、域名和系统功能等细节。对手可能利用这些数据通过地址或域名来识别目标。通过TLVs揭示的系统功能可能会通过分类目标（例如，作为电话或DOCSIS电缆设备）来获取支付卡行业信息（PCI）。需要注意的是，某些组织特定的TLVs可能包含个人身份信息（PII）或支付卡行业信息（PCI）。这类TLVs的例子包括库存TLV，它促进了硬件、软件和固件版本的交换，以及功能TLV，它使得可以确定连接设备所支持和启用的功能。

4)802.1X: 基于端口的网络访问控制，也被称为IEEE 802.1X，建立了一个涉及多种消息类型的全面框架[16]。重要的是，其中一些消息可能携带PII。例如，负责传输EAP响应的局域网上的可扩展认证协议（EAPOL）消息有可能包含诸如用户、主机或两者组合的登录凭证[17]。此外，EAPOL公告传达站的能力。在被动对手位于目标和EAP验证者（通常是接入点）之间的场景中，如果EAP方法缺乏保密性保护，对手可以拦截通过该方法交换的信息。此外，对手还可以审查公告数据，有可能推断或识别目标类别。对于位于目标和EAP验证者之间的主动对手，存在成功冒充EAP方法中合法响应者的风险。这种欺骗行为可能会发展到目标暴露其身份的程度，包括客户端证书中的主体名称。

B. 802.11MAC子层

除了地址字段之外，IEEE 802.11 帧还携带了大量信息，有助于将目标与个人设备关联起来。例如，在尝试连接到AP时，STA可以通过可选字段或能力元素披露支持的选项。在超过4000页的详尽802.11标准文档中，详细描述了数百种选项。这些选项的支持取决于诸如Wi-Fi驱动程序、其代际、覆盖的操作系统以及STA厂商的选择等因素。在同一Wi-Fi热点内的STA之间检测出独特元素可以识别特定设备。这些选项在STA关联请求和其他管理帧中十分特别，对于建立和维持连接至关重要。由于它们在促进成功连接方面的重要作用，802.11管理帧通常携带大量的信息。例如，AP使用信标帧广播有关其无线网络的信息。在AP与特定个人相关联的情况下（如在一个家庭或小型商店），

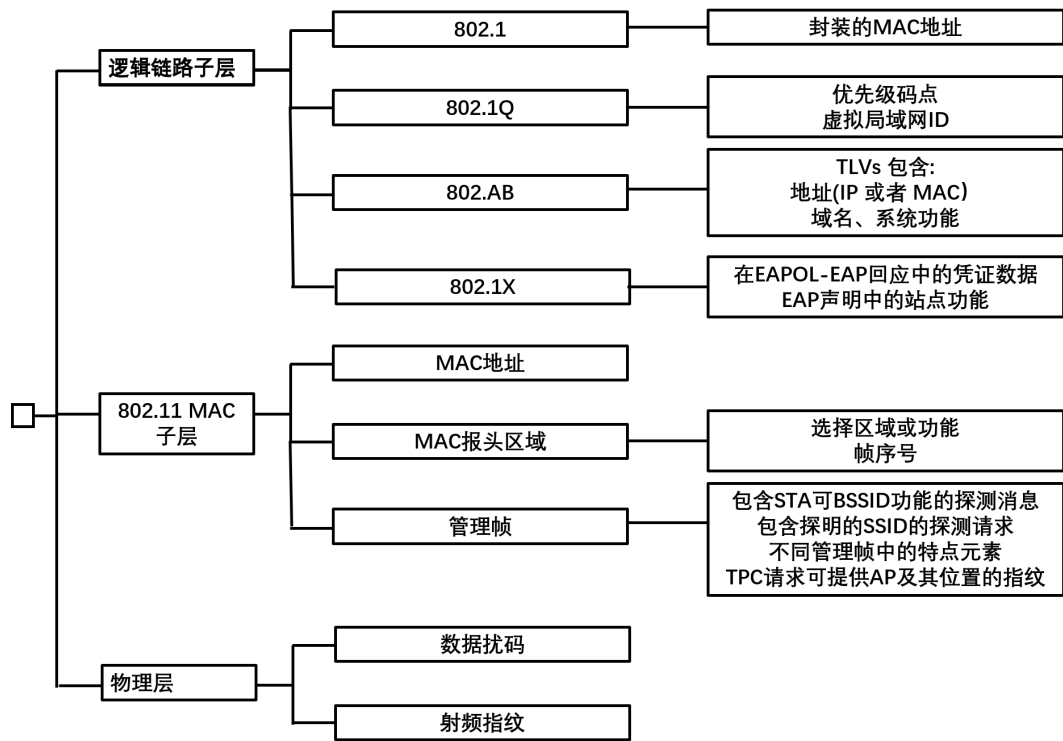


图 7. 在IEEE802域中公开的PII/PCI协议层

信标数据可以转变为PII，从而唯一地标识AP，并将其传输的所有流量链接到网络所有者。

被动对手可以利用信标帧中的各种元素——如能力字段、SSID、RSN IE、EDCA参数集、QoS能力IE和QoS流量能力——来建立AP的独特指纹。此外，主动对手可以发送TPC请求并分析AP在后续信标帧中的响应，以创建AP及其物理位置的指纹。通过检查信标帧中包含的流量指示图（TIM）中的关联ID（AID），可以确定哪些STA有由AP缓冲的数据。潜在攻击者可以利用这些信息来识别和区分已连接的客户端。此外，知名的攻击方式，比如邪恶双胞胎攻击[18]、[19]，依赖于通过信标帧宣传与另一系统相同的SSID。这会促使受害STA无意中尝试连接到恶意AP，使攻击者能够拦截帧并可能从目标STA收集PII。其他管理帧，包括探测请求/响应、重新/关联请求/响应、去认证、动作、去关联等，也可以被用于信息收集和潜在的PII或PCI暴露。例如，探测响应结构与信标非常相似。由客户端发起的探测请求可能会泄露所寻找的SSID，从而存在PII暴露的风险。去关联帧值得注意，它包含一个原因代码、一个或多个厂商特定元素，以及在PMF启用时可选的管理MIC元素，尤其是在帧发送给组的时候。所有这些组件提供了唯一识别发送者及其在网络基础设

施中位置的途径。

C. 物理层

被动射频分析具备识别负责在物理层传输IEEE 802.11帧的网络接口卡（NIC）的能力。这种方法利用了发射机硬件中固有的细微缺陷或独特特征，这些特征在制造过程中产生，并且尽管NIC总体上相似，但这些特征会在所有NIC中持续存在。这些内在的缺陷在传输信号中产生了独特的标识，从而为每个设备建立了有效的唯一指纹[20]。

对设备指纹识别的另一个贡献因素是用于扰频器的种子。在IEEE 802.11中，扰频通过将帧的二进制载荷与一个伪随机序列进行异或操作来提高物理层的性能。这个过程生成了一个比特分布均匀的不相关二进制序列，以最大化信息内容。然而，扰频器种子的选择引入了一个潜在的攻击向量。在多个消息中关联扰频器状态种子可以导致设备和驱动程序的重新识别，从而绕过现有的隐私保护机制[21]。

这种基于物理层特性的设备识别方法利用了硬件层面的独特性，即使是在相同的型号和制造商之间，也能够区分不同的设备。通过分析无线电信号中的细微差异，攻击者可能不需要依赖高层协议的数据就能识别出特定的设备，这增加了隐私泄露的风险。因此，为

了保护用户隐私，需要考虑如何在设计无线通信系统时减轻这些硬件特征带来的风险。

IV. 与RCM相关的研究

本节选择性地介绍了与RCM相关的研究，并将其组织成三个子部分：

- 基于MAC地址的人群追踪和定位中的隐私问题及RCM的采用：这一子部分考察了基于MAC地址的人群追踪和计数系统、Wi-Fi设备定位技术及其与RCM发展的关联。它讨论了这些系统中的隐私问题以及与公民自由相关的问题。此外，还介绍了提供有关RCM采用数据的研究。
- 去随机化技术：这一子部分介绍了为追踪和计数人群而开发的去随机化技术，即使在启用了RCM的情况下也能使用这些技术。
- RCM对Wi-Fi服务和程序的影响：这一子部分描述了专注于评估RCM对Wi-Fi服务和程序影响的研究努力。

这三个子部分的关键点总结如图8所示。

A. 基于MAC地址的人群追踪和定位中的隐私问题及RCM的采用

追踪人员和人员行为：目前，MAC地址已在多个个人设备的指纹识别系统中发挥作用。即使没有恶意图，一些公司也已经开始追踪个人设备以监控店内顾客的行为[22]、[23]、[24]，并收集移动数据用于各种目的[25]、[26]、[27]，如为游客提供推荐系统的服务[28]，或是在智能运输系统（ITS）领域内基于Wi-Fi的交通检测应用[29]、[30]、[31]。

许多研究利用Wi-Fi技术在如足球比赛、大学校园和医院[32]、[33]等人员密集的地方，收集人员移动数据。Wi-Fi还在城市区域内追踪人员方面发挥了重要作用[34]、[35]、[36]。同时，研究人员还探索了与人群动态相关的群体检测、等待时间、速度和经常穿越的路径[37]、[38]等内容。当然，这种做法引发了重大的隐私问题，因为只需四个时空点就可以轻易识别出个人的独特移动模式[39]。这些问题正是促使设备制造商和IEEE引入RCM的原因。

人员计数：某些研究表明，对于区域内的人员计数等特定应用，可以越过RCM以发挥功能。例如，Maltoni等人[40]介绍了一种基于Espressif ESP8266板的高成本效益且低功耗的人员计数器，并分析了整体解

决方案成本。该设备可以从Wi-Fi数据包中绕过RCM收集MAC地址。通过实际实验，他们证明对于此类应用，将重点放在识别个体上，无需追踪特定设备便可进行人员计数。他们系统的实现方式为过滤掉包含RCM或具有未分配组织唯一标识符（OUIs）地址的数据包。尽管存在一些准确性问题，但这种方法需要的资源最少，并且可以由传感器本身实现。该研究强调，随着物联网设备变得越来越便宜，即使是个人也可能在一个城市或室内环境中建立一个用于恶意目的的个人计数系统。SenseFlow是一个轻量级的传感系统，其被动收集来自个人智能手机的探测请求，而无需了解环境特征或进行指纹识别便可用于监测定义区域内的人数并跟踪其流动，[41]、[42]。

两项显著的研究展示了基于Wi-Fi系统的公共交通运输乘客流量监控的应用[43]、[44]。这些工作提供了准确评估运输系统内乘客流量的宝贵见解。此外，Paradedda等人[44]对现有文献进行了涵盖了公共交通领域的各种Wi-Fi应用的全面综述，包括估计公交站、车站或终点站等待乘客数量的高级技术，以及用于计算上下车事件的复杂数据分析方法。

Wi-Fi 设备定位：Scheuner等人[45]介绍了一个可越过RCM的系统，他们提出了开源系统Probr，通过监控Wi-Fi流量来监测房间使用情况、并进行设备定位、人员追踪和设备统计。最近，Abedi等人[46]展示了802.11 Wi-Fi协议中的安全性和隐私漏洞，揭示了在无需合作的情况下即时且隐秘地确定室内环境中Wi-Fi设备精确位置的方法。作者利用了802.11中的省电机制来识别网络中的所有设备，并使用目标数据包进行位置估算。这些信息可能被窃听者用于恶意目的，如跟踪个人或确定酒店房间的占用情况。

许多研究提出了不同的方法来对Wi-Fi设备进行定位，包括通过专用AP来确定启用Wi-Fi的移动设备的地理位置[47]、[48]、[49]、[50]。这些专门的AP拦截来自上述移动设备的Wi-Fi数据包，量化与这些传输相关的接收信号强度（RSS）。然后使用这些测量的RSS值来进行定位。

RCM普及情况：自从实施RCM，已经有了多项评估其在现实世界中的实际使用情况的研究。这些研究的首要发现是RCM并未被用户广泛采用[51]、[52]、[53]。

隐私和民众担忧：如今，许多网络基础设施供应商为部署大型Wi-Fi网络的组织提供定制的地理营销

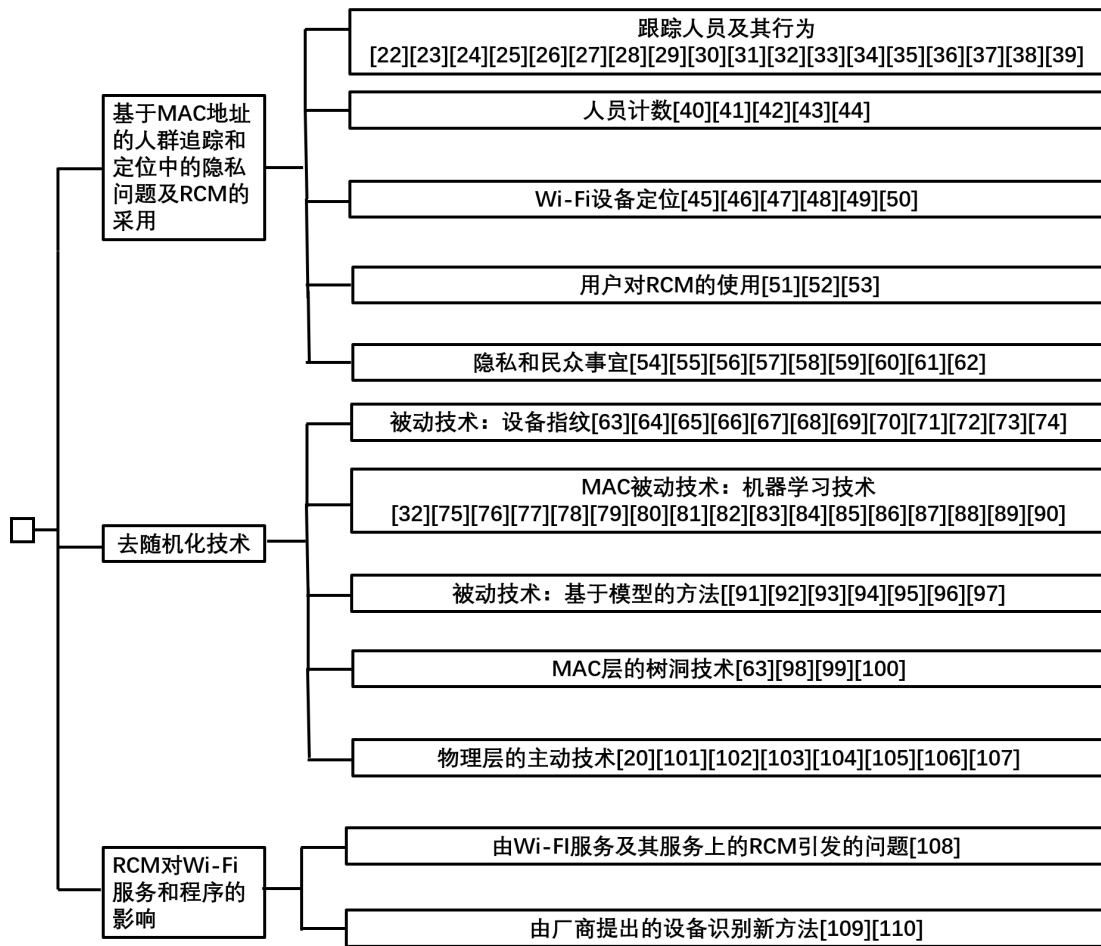


图 8. 与RCM相关的研究工作

解决方案，例如购物中心、酒店和机场。然而，由于隐私问题，传播有关这些系统的信息面临重大挑战。一件2012发生的案例展示了这些问题，当时一家名为Renew的公司在伦敦市安装了12个具有捕捉无线MAC地址信息能力的回收箱[54]。该公司甚至提议在洗手间部署这样的传感器来推断用户的性别。随后，在2013年8月，伦敦市政府介入并要求终止试验，尽管该公司声称收集的数据“极其有限，加密，汇总和匿名化”。类似的隐私担忧在2019年5月再次出现，当时伦敦交通局（TfL）宣布他们打算收集MAC地址数据以研究车站内的乘客流动情况[55]。虽然TfL声称会对MAC地址进行加盐哈希处理，但隐私倡导者对这种方法提出质疑，因为它仍然需要在观察中链接相同的MAC地址。这些例子突显了在利用Wi-Fi技术进行人群追踪和定位时，隐私保护措施的重要性以及公众对此类技术应用的关注。随着技术的发展，确保隐私保护成为设计和实施此类系统的关键考量因素。

B. 去随机化技术

尽管一些厂商引入了MAC地址随机化，但后续的研究表明，攻击仍然有可能区分和追踪现代设备。以下研究展示了即使MAC随机化可以保护个人隐私，但追踪技术仍可进行追踪[63]、[98]。为了在特定时间段内将来自同一设备的帧或信号聚类，研究者提出了几种去随机化方法，这些方法可以分为被动嗅探、主动嗅探和物理层分析。值得注意的是，由于专门设计用于对抗去随机化技术的出现，某些传统方法遇到了可行性挑战[111]。面对这一持续的挑战，当前的研究致力于探索新的去随机化方法，并设计新的随机化技术，以在这场持续的竞争中保持领先。

C. 被动技术

设备指纹：在被动嗅探的情况下，即使移动设备未被主动使用，它们每小时仍然广播大约2000个探测请求，产生大量数据[64]。这些数据可以用于建立重新识别使用RCM传输的消息的算法。表明即使在启用

了RCM, Wi-Fi探测仍可能带来潜在隐私风险。例如, Matte等人[65]提出了一种对抗随机化过程的算法, 该算法以一组探测请求帧作为输入, 并将它们与设备关联起来。根据帧间时间、突发间时间和帧发送频率创建签名, 然后使用Franklin距离比较相似性。相似性距离低于某个阈值的MAC地址之间会被聚合。Nitti等人[66]介绍了一种确定两个探测请求帧是否源自同一设备的方法。针对所有具有相同IE ID的MAC地址的探测请求基于到达时间差和序列号计算得分。另一个依赖于探测请求指纹识别的研究是[63]。作者提出了一种使用IE ID指纹识别的设备追踪算法。该算法首先根据IE ID将探测请求分组为簇, 然后通过分析序列号的可预测行为尝试区分同一簇中的设备。如果两个探测请求的到达时间差小于500秒且序列号差小于64, 则认为它们来自同一设备。类似地, 一个低成本的公共空间占用估算监测系统也可基于观察每个智能手机在探测请求中的唯一指纹字段[67]进行识别。

尽管随机化程度增加, [68]的作者仍然开发了一个高效的群体监测系统, 该系统基于探测请求的被动检测。通过测量10毫秒内接收到的探测请求数量来统计设备。另一种群体监测解决方案见于[69], 它结合了探测请求中首选Wi-Fi AP的SSID信息和现有Wi-Fi AP的信息, 通过后处理确定不同地点的日访客数量。[70]采用了类似的方法, 其目标是去匿名化参加特定活动的个人来源。为了实现这一目标, 探测请求的首选网络列表(PNL)中的每个SSID都与其各自的GPS坐标相关联。然后利用这些信息在去匿名化过程中确定相关人员的出处。[71]提出了一种在监控大型人群的同时保护隐私的计数系统。所提出的方案将数学模型应用于观测到的探测请求消息速率, 而不考虑这些消息的内容。因此, 这种方法不受RCM的影响。这与其它要么去匿名化探测请求要么识别非随机化探测请求突发的Wi-Fi监测系统形成对比[71]、[72]。探测请求流量的统计特性分析也被用于开发群体估计方案[73]、[74]。

机器学习技术: Ribeiro等人[75]介绍了一种使用自动分类技术的计数和追踪方法。该研究基于在马德拉群岛实际条件下收集的4年探测请求数据。他们使用了七种无监督分类算法来计算平均准确率。研究表明, 随着时间的推移, 使用出厂MAC地址的比例从超过50

另一个用于分析城市移动性的系统利用机器学习算法来检测人流, 同时保护隐私[78]。类似地, Gebu等人[79]提出了两种人员计数和移动性检测的方法论。但

是, 最近的隐私保护方法完全随机化了探测请求的序列号, 使得前述方法变得不那么可靠。He等人[80]提出了Cappuccino, 这是一种新的隐私保护方法, 它在RCM下捕捉探测请求的关联。Cappuccino是一个估计成对帧相关性和随时间关联帧的系统。它使用自监督估计器来确定帧的相关性, 考虑多个模式, 包括信息元素、序列号和接收到的信号强度。通过品牌分割捕获的探测请求的多维统计属性的相关性已在[81]中用于研究移动模式。

两种新的群体监测算法Vision和TrueSight在[82]中被提出。这些算法提供了设备数量的估算, 并成功展示了基于MAC地址的群体监测的持续可行性。Vision算法利用数据帧和信标帧, 有效缓解了随机化的影响。此外, TrueSight算法采用序列号和分层聚类技术, 准确估计监控区域内的设备数量。最近, Uras等人[83]提出了一种新的MAC地址去随机化算法, 旨在将同一设备生成的探测请求分组。该算法有效地结合了传统上孤立考虑的特征, 包括发送帧中的可选字段的内容和长度, 以及随时间编号的速率。利用这些特征, 使用基于密度的聚类算法[84]将帧与同一设备关联。所提出的聚类方案的性能评估是使用公开可用的数据集进行的[85]。机器学习技术已被用于理解人群行为并发现模式[86]、[87]。

在最近的一项研究中, 一种新颖的去随机化方法被考察, 用于监测特定区域内个人或人群的存在和移动[88]。该方法采用独特的聚类和匹配程序, 通过分组相似的网络管理消息及其对应的无线电频道特性来检测单个设备。这种创新的方法提高了识别和跟踪监控环境中设备的准确性和效率。

对于802.11-2016细粒度定时测量(FTM)的分析揭示了使被动观察者能够提取任何客户端测量的距离的漏洞, 从而提供定位能力。值得注意的是, 即使启用了RCM, 这些弱点仍然存在[89]。此外, 简单观察FTM帧可以促进个别芯片组的识别[90]。对于使用相同芯片组的类似设备, 唯一的软件变化允许使用神经网络区分每个设备。为了减轻这些识别风险, 可以通过统一供应商之间的参数范围并适当实施MAC和计时器随机化来实现潜在的补救措施。

基于模型的方法: 在[91]中, 一项深入研究分析了6个月高时间分辨率的Wi-Fi和GSM轨迹, 展示了仅通过每人每天一次的GPS观测来估计AP位置和使用模式的能力。该研究不仅强调了利用无处不在的Wi-Fi路

由器实现高分辨率户外定位的潜力，也引发了对侧信道位置跟踪相关的隐私问题的重大关注。一种先进的方法被用来利用澳大利亚8000个Wi-Fi设备广播的信息，实现了作者所称的SSID画像[92]。SSID画像涉及对收集的数据进行综合分析，特别关注与设备上保存网络相关的SSID。这个分析过程促进了根据社交连接关联不同设备的能力，使得识别经常光顾相似地点、拥有共同兴趣或家庭关系的人成为可能。

类似于SSID画像的方法，研究人员还调查了特定Wi-Fi地点相关的用户人口统计信息。这些调查方法涵盖了从被动扫描技术[77]到通过HTTP访问主动提取元数据的一系列方法[93]。

Hong等人[94]介绍了CrowdProbe系统，该系统部署在一个多层博物馆内，旨在准确理解携带具有RCM功能设备的博物馆访客的移动模式。CrowdProbe的有效性得益于其利用了6个月的历史数据收集，并结合了特定于博物馆环境的空间和时间约束。Sherlock系统[95]、[96]则侧重于存在检测而非轨迹追踪。该系统基于成本效益高的ESP8266板，利用收集的数据实施占用解析模型。值得注意的是，该模型利用环境信息而不需要具体MAC地址的知识。

在[97]中，介绍了一种经济且计算效率高的系统，设计用于实时计数公共交通工具如公交车和地铁车厢中的乘客数量。它通过观察用户智能手机的电子指纹，并使用数学模型来细化和调整原始数据值来实现这一目标。

这些基于模型的方法展示了如何利用Wi-Fi和其他无线通信技术的数据，结合机器学习和数据分析算法，以实现各种应用，包括但不限于人员流动监测、群体行为分析、室内导航和安全监控。同时，这些方法也凸显了保护个人隐私的重要性，因为即使是在匿名化处理后，某些特征仍可能被用来重新识别个体。因此，在开发和部署这些系统时，必须考虑并实施适当的隐私保护措施。

D. MAC层的主动技术

Vanhoef等人[63]使用主动技术分析800万个探测请求，识别出大约170,000个MAC地址。他们发现最有效的方法是利用Wi-Fi保护设置(WPS)参数，这些参数连接到一个与设备出厂MAC地址相关的通用唯一标识符-注册者参数。这种方法使得追踪真实的MAC地址更加准确，并减少了计数错误。Martin等

人[98]研究了将随机MAC地址追溯回单个设备的技术。他们采用了主动嗅探方法，利用漏洞并实施攻击，如KARMA攻击（通过探测的BSSIDs创建一个恶意接入点）和RTS/CTS攻击，在与AP进行连接协商期间获取真实MAC地址。这需要知道设备的SSID。

E. 物理层的技术

为了使用Wi-Fi探针定位人群，Potorti等人[103]采用了基于之前扫描的室内位置接收到的RSSI值的指纹插值技术。这项技术能够识别出人群聚集的热点区域。Wi-Fi RSSI测量提供了有助于估计某个区域内行走人数的信息[104]、[105]。这些技术的核心概念是事件间隔时间的鲁棒性，这些时间对应于接收到的信号中的下降事件，对墙壁引起的信号衰减具有抵抗力（与精确的下降值形成对比）[104]。通过分析观察到的事件间隔时间，该方法能够估算监测区域内的人数。基于RSSI构建一个神经网络多分类器，可以对来自多个来源的Wi-Fi信号进行分类，这种方法已被用于城市流动检测系统[106]。

在[107]中介绍的计数系统依赖于集成分类方法，结合了使用不同无线信道特征训练的学习工具，将未修改的Wi-Fi无线电基础设施转换成一个多功能的被动人员计数传感系统。

F. RCM对Wi-Fi服务和程序的影响

据作者所知，目前还没有科学工作专门针对RCM对Wi-Fi服务和程序造成的问题进行研究。关于这一主题的资料主要来自厂商撰写的博客和白皮书。例如，在[108]中，作者讨论了如果MAC地址被更改或定期变化，一组重要的服务和程序是否还能正常运作。作者建议现在做出调整以防止未来可能出现的问题。

商业解决方案提供了新的设备识别方法。例如，LEVL平台[109]为网络上的每个设备提供一个独特的标识符(LEVL-ID)。LEVL-ID的生成无需用户输入任何信息，完全是零接触式。它不侵犯用户隐私，因为它不依赖于用户数据或PII来进行识别。LEVL-ID仅依赖于内部网络已知的设备特性，是一个派生的标识符，不会存储在设备上，是MAC地址的隐私友好替代方案。另一个专有解决方案的例子是Device Unique ID (DUID)[110]，它为使用RCM的设备提供唯一身份。DUID也是一种在保护用户隐私的前提下，确保设备在网络中拥有独特标识的方法。这些商业解决方案展示

了如何在MAC地址随机化的环境下,通过创新技术保持Wi-Fi服务的功能性和稳定性,同时保护用户隐私。预计随着RCM的普及,会有更多类似的解决方案出现,以适应不断变化的技术环境和隐私保护需求。

V. RCM解决方案

关于MAC地址泄露个人位置和活动信息的担忧,在2000年代末随着智能手机市场迅速扩张加剧。在2010年代初,专注于全球监控和隐私话题的工作坊,[112],认识到了这一漏洞。这些工作坊强调了这是IEEE标准中MAC地址设计的意外后果。

IEEE 802.1(架构组)和802.11(无线局域网组)内部的讨论得出结论,MAC地址的设计初衷是保证在整个网络会话期间保持唯一性和稳定性,以确保网络连接及相关服务的连续性。然而在会话之外没有对客户端站的身份做出任何假设,因为在那个时间段内站台不需要从网络获取任何服务。这个方面在标准中没有明确说明,随后IEEE 802.11工作组在802.11aq修正案[113]中加入了此澄清。该修正案特别关注预关联发现交换,并在不同操作系统开始引入RCM的同时期进行开发。

不同的厂商采用了各自的命名约定来描述这种做法,有些厂商希望其选择能够成为事实上的标准,从而声称对该实践的所有权。不过,在标准组织内部,这种做法最广泛接受的术语很快变成了RCM

RCM旨在解决由于MAC地址的稳定性和唯一性所带来的隐私问题,尤其是在用户不活跃或未连接到特定网络时。RCM允许设备在网络交互之前使用临时的、随机生成的MAC地址,而不是永久性的出厂MAC地址,从而减少长期跟踪的可能性,增强了用户的隐私保护。同时,这也反映了标准制定者和技术开发者对于隐私保护日益增长的关注,以及对技术标准如何影响个人隐私理解的不断深化。

A. 随机MAC地址的出现

随机MAC地址必须遵循IEEE 802-2014 [114]和802c-2017 [115]中定义的本地管理地址结构。在图9中,展示了MAC地址的结构,特别强调了初始八字节的最不重要位和次不重要位,分别标记为M和X。这些位传达了关于地址类型的关键信息,用以区分单播或组播以及全局唯一或本地管理。本地单播地址遵循以下格式: x2-xx-xx-xx-xx-xx, x6-xx-xx-xx-xx-xx, xA-xx-xx-xx-xx-xx 和 xE-xx-xx-xx-xx-xx。

过去,MAC地址的选择是由厂商分配的,厂商从IEEE获得一个唯一的组织唯一标识符(OUI)。24位前缀包括特定设置的M和X位,以及分配的OUI。然后,厂商通过生成一个用于低24位的唯一24位值来完成48位MAC地址。通常,这些位作为递增计数器生成,在工厂分配,并永久编程到网络接口卡(NIC)中。



图 9. MAC地址格式

B. 算法

MAC地址的随机生成缺乏标准化,导致不同实现之间存在差异。生成算法必须产出符合IEEE 802标准的安全且不可链接的MAC地址,防止对手在新生成的MAC地址和之前使用的地址之间建立联系。此外,生成的地址应遵循IEEE 802标准规范,长度为48位,以OUI开头,并排除诸如广播(FF:FF:FF:FF:FF:FF)和组播等保留地址。

满足这些要求的一个算法示例可以在[116]中找到。作者使用了一个由不可预测的随机种子初始化的MD5哈希前向链。仅使用哈希值的一部分来生成地址,以防止对手获取完整的哈希值。此外,他们结合了一张来自知名无线网络接口卡(NIC)制造商的有效OUI表。最终的随机MAC地址通过将OUI与哈希值的一部分连接起来获得。通过选择常见的无线网卡的OUI,随机生成的地址看起来像是真实的、无法与真实地址区分开来。地址选择过程可以进一步优化,仅使用分配给无线NIC的地址块。

每个客户端进行MAC地址的随机生成引入了碰撞的可能性。在一个时间间隔 t 内地址碰撞概率的上限可以通过生日悖论[118]计算得出:

$$p(t) = 1 - \left[1 - \frac{n(n-1)}{2b+1} \right]^{t_f}$$

其中 b 是随机选择的地址位数, f 是地址变化的频率, n 是在同一局域网中的客户端数量。

为了检测碰撞,[116]中提出了一个机制,利用发送反向ARP请求,在该请求中客户端在源字段添加一个随机选择的地址,而实际请求的是第二个随机选择的地址。客户端监听对第一个地址的回复。如果有回复,

则表明网络中另一个客户端正在使用第二个地址，从而能够检测到碰撞。在这种情况下，客户端会重复带有新随机选择地址的请求，直到找到可用地址为止。虽然这个机制仍然允许在第一个随机选择的地址上发生地址碰撞，但客户端只使用此地址发送少量的反向ARP请求，从而最小化对网络的重大干扰。

C. 生成规则

另一个关键点涉及用于决定“何时”生成随机MAC地址的策略。两种基本方案代表了历史上用于定义设备MAC地址的方法的变化。这些变化表明，随机MAC地址通常是在设备首次启动或每次启动时由设备生成的。然而，这些方案并未充分解决Wi-Fi潜在的隐私暴露问题。为了解决这一问题，随机MAC地址需要遵守以下三项生成规则[112]：

- 按网络生成的MAC地址：在创建新的网络连接时生成这种地址，并通过SSID来标识网络。生成的地址随后以SSID为索引存储。当设备重新连接到具有相同SSID的网络时，它会使用保存的MAC地址。
- 周期性生成的MAC地址：定期生成MAC地址，通常是每十二小时一次。当MAC地址发生变化时，STA会断开当前会话并使用新MAC地址重新连接。这个过程需要建立一个新的WPA/802.1x会话，包括重新进行EAP、TLS和其他相关程序的协商。目前尚不清楚是否可以在MAC地址变更期间保留任何TLS会话恢复票证（如EAP-TLS所用）。如果使用DHCP，则会生成一个新的动态主机配置协议唯一标识符（DUID），以确保与之前的连接没有关联，并且通常会分配新的IP地址，使得难以轻易识别个别用户或特定用户组。使用该生成方案的场景包括仓库中的工作平板电脑、企业分发交换机或大型机场中的AP。
- 按会话生成的MAC地址这种类型的MAC地址是为每个会话生成的。由于地址仅在建立新会话时更改，因此不涉及断开或重新连接的过程。

D. 操作系统层面对RCM的研究

设备的操作系统（OS）在管理MAC地址随机化过程中起着关键作用。由于缺乏标准化算法，每个操作系统实现了独特的随机化操作和策略。Linux操作系统：Linux系统自内核3.18版便引入了MAC地址随机化，

大多数Wi-Fi驱动程序配置为，在STA未关联时每几次突发传输最多更改一次MAC地址[65]。这里定义的“突发”指在小于10毫秒的时间窗口内发送的一组帧。wpa supplicant中随机MAC地址的默认持续时间为60秒。这些随机MAC地址可以是完全随机的，也可以部分随机，其中前三个八位字节可能保留以匹配实际的OUI。
Windows 10或更高版本：对于Windows 10及更高版本采用两种类型的随机MAC地址化方案[119]。第一种类型适用于所有网络，在连接前的探测请求、授权和关联阶段使用随机MAC。第二种类型适用于特定网络，在下一次连接时使用随机地址。在这种情况下，用户可以选择为特定网络使用固定的随机MAC地址或每天更改。

Android框架：Android实现了两种类型的MAC随机化——持久性和非持久性[120]。在持久模式下，Android基于网络配置文件的参数（如SSID和安全类型）生成随机化MAC地址。因此，即使用户忘记了并重新添加Wi-Fi网络，MAC地址也保持不变。持久MAC地址对依赖MAC地址连续性的网络非常重要，例如用于设备识别，让用户绕过登录界面或启用家长控制。在Android 12或更新版本中，某些网络使用非持久性随机MAC地址。Wi-Fi模块要么在每次连接开始时重新随机生成MAC地址，要么使用现有MAC地址连接。如果DHCP租期已过期且自上次断开该特定网络以来超过4小时，或者当前随机化MAC地址是在超过24小时前生成的，设备则会生成新的MAC地址。重要的是，MAC地址重新随机化仅在建立新连接时发生，Wi-Fi不会主动断开以重新生成一个MAC地址。这种方法在隐私保护和Android设备的无缝网络连接需求之间取得了相对平衡。

iOS：MAC地址随机化自iOS 8引入，在iOS 15、iPadOS 15和watchOS 8中，设备会为每个Wi-Fi网络专门随机生成唯一的MAC地址[121]。当用户重置网络（或设备）设置，或设备在过去6周内未加入该网络时，设备会删除该MAC地址并生成新的地址。MADINAS工作组对不同操作系统执行的测试结果总结在表II [122]中。表格显示了操作系统是否按网络、按新连接或每日生成随机地址，是否支持按SSID配置，是否支持扫描时的地址随机化，以及是否默认启用这些功能。

表 II
从不同操作系统中观察到的行为

地址改变方式	Linux	安卓10	Windows10	iOS 14+
每个网络	Y	Y	Y	Y
每次连接	Y	N	N	N
每天	N	N	Y	N
每个识别的SSID	Y	N	N	N
每次扫描	Y	Y	Y	Y
每次默认扫描	N	Y	N	Y

E. 802.11aq角度的RCM

IEEE 802.11aq标准的制定过程充满了关于隐私保护和网络稳定性的激烈讨论。隐私至上的倡导者支持STA自由改变其MAC地址的权利，而网络稳定性支持者则强调需要仔细审查4000多页的标准文档，以防止可能对网络稳定性或向后兼容性造成破坏。经过这些讨论，IEEE 802.11aq标准在条款4.5.4.10中承认了MAC地址（连同帧序列号、加扰数据或探测请求中的信息等参数）具有唯一识别STA的潜力。为了减轻基于MAC地址的STA跟踪风险，IEEE 802.11aq提出了一系列政策建议，其中包括：

采用非连续的序列号和加扰数据：这有助于减少通过序列号或加扰模式追踪STA的可能性。避免特定SSID查询：在探测请求中不使用特定SSID，以减少暴露身份的风险。

定期更改MAC地址：当STA未与AP关联时，应频繁更改其MAC地址为随机值（条款12.2.10）。重要的是，这种更改不应遵循固定的规律间隔，而是要经常进行，以避免长期关联。然而，一旦STA开始进行可能在AP上建立状态的交换，它就不应再更改其MAC地址。任何STA预期从AP获得响应的交换都要求在整个对话过程中保持一个稳定的MAC地址。这个稳定的MAC地址可以是本地生成的（即通过RCM随机化MAC地址）。关联到AP是一个典型场景，但预关联交换也包括在内。例如，STA可能会发起预关联查询以获取AP提供的服务列表，如IEEE 802.11aq所规定的多种服务。这种交换使用访问网络查询协议（ANQP），其中AP可以提供部分或摘要式的响应，并附带一个标志指示有更多信息可用。随后，STA可以根据需要请求更详细的信息。在此整个交换过程中，STA应当保持相同的MAC地址。

对于跨AP漫游的情况，IEEE 802.11aq明确规定STA应在连接到整个ESS期间保留相同的MAC地址，

即使在同一场地内切换具有相同SSID的不同AP之间也是如此。ESS在802.11标准中有明确定义，但此定义有意引入了一定的模糊性。ESS由一个或多个互连的BSS组成。

从逻辑链路控制层的角度看，ESS在任何STA关联到其中一个BSS时表现为单个BSS。在802.11的上下文中，LLC位于MAC层之上（IP层之下）。因此，ESS在STA关联到AP时变得明显，并且只要STA保持与该AP的连接或在其范围内漫游而不终止连接，ESS就会持续存在。STA离开ESS是指它解除关联。这意味着一旦STA解除关联，它就不再连接到任何BSS或ESS，因此可以更改其MAC地址并发起新的连接。

综上所述，STA在解除关联后便不再被视为连接到BSS或ESS，从而可以在重新连接时更改其MAC地址。这一机制确保了在不影响网络功能的前提下，增强了用户隐私保护。

因此，根据IEEE 802.11aq标准，STA在管理MAC地址时有几种选择：

使用原始MAC地址：STA可以选择使用其出厂设置的MAC地址进行所有SSID的关联。

混合使用原始和随机MAC地址：STA也可以同时使用原始MAC地址和随机化MAC地址，并将特定的MAC地址与特定SSID相关联，这样就可以把ESS视为所有广播那个SSID的AP。在此情况下，STA可以为不同的SSID使用不同的MAC地址，这与多数站台供应商常用的实现方式相一致。

依据地理位置判断：STA还能根据其地理位置决定，认为提供相同SSID但不在连续区域内的两个AP不属于同一个ESS。因此，STA可以选择为不同地点（即使它们有相同的SSID）生成不同的MAC地址。例如，智能手机可以在一家咖啡店的SSID下使用一个MAC地址，而在同一条连锁但不同位置的另一家咖啡店的同一SSID下使用另一个MAC地址。理论上，这假设STA在操作系统层面上具有位置感知功能，能够区分同一条连锁中不同店铺发布的相同SSID。但实际上，这个条件往往无法满足。

当STA解除关联时，STA与AP的关联关系结束，而ESS只在STA关联到AP之后才会显现。因此，STA可以在不同的会话中为相同的SSID使用不同的MAC地址。例如，智能手机可能在早餐时间阅读新闻时为家庭SSID使用特定的MAC地址；但当用户移至办公室后，智能手机会从当前AP解除关联，随后为新的连接生成

并使用新的MAC地址。晚上回家后，智能手机可能会再次为家庭SSID使用不同的MAC地址。

还可以设想更为激进的策略。比如，STA可以监控网络活动，识别无数据传输的不活跃期。在这样的空闲时间内，STA可以选择从当前BSS和ESS解除关联，从而允许生成新的MAC地址。STA然后可以立即重新关联到同一个AP，以此为后续通信改变其MAC地址。

需要注意的是，IEEE 802.11aq并没有明确规定这些具体场景，因此其规范文本仅涵盖上述详述的内容。尽管如此，标准承认STA关联时ESS的暴露和因解除关联而导致的关联终止，为这些MAC地址管理的可能性奠定了基础。未来可能需要进一步研究和标准制定，以全面探讨和监管这些高级策略的实施。

F. RCM对网络基础设施和用户体验的影响

大多数操作系统采用了一种MAC到SSID的映射结构，即STA在与新的SSID关联时生成一个新的MAC地址，并为后续连接到相同的SSID保留该MAC地址，而不考虑地理位置因素[112]。然而，这种方法提供的隐私保护有限，因为对于给定的SSID使用相同的MAC地址，当该SSID关联了可识别信息时，可能会方便用户跟踪。为了解决这一局限性，一些供应商正在探索限制MAC地址生命周期的策略，如第V节所述。但重要的是要考虑，这些激进的MAC地址随机化方案可能对网络基础设施产生负面影响，从而影响STA用户体验。

最初STA的MAC地址作为唯一标识符，这激发了依赖MAC地址稳定性的机制的发展。因此，当MAC地址频繁更改时，这些机制可能不再按预期工作，可能会在网络中引起中断或效率低下。因此，在增强隐私和保持网络稳定性之间取得平衡对于确保最佳性能和用户满意度至关重要。图10概述了这些问题，而在接下来的段落中将进行详细讨论。

- **基于基础设施的位置服务：**STA发出的信号，特别是探测请求，已经被用来推断其位置。这种现象源于802.11发现机制，在企业环境中用于资产定位以及在公共空间中收集必要统计数据，以辅助布局优化、安全措施和针对性的营销策略[22]。这些统计数据包括在不同区域的停留时间和个体在商店内的典型路径，用于各种目的。例如，帮助企业做出广告放置和战略产品推广的决策，协助与安全相关的任务，如识别逃生路线和最佳安全位置。此外，用户可以选择参与定向营销计划。在这种情况下，即

使STA未连接到Wi-Fi网络，当用户到达商店内的特定位置时，也可以通过应用程序提供广告或优惠券。然而，发现过程中MAC地址随机化对这些机制的持续实施提出了挑战，主要是选择加入和企业资产跟踪场景，而对不必要的客户跟踪影响较小。

- **自动重新认证：**在使用捕获门户进行自动重新认证时，某些场所（如酒店）会对高级Wi-Fi服务收费。他们使用MAC地址来识别授权设备。如果MAC地址每天变化，用户可能会为整个入住期间的服务多次付费。
- **覆盖漏洞检测：**在企业环境中，随着时间的推移，Wi-Fi网络的楼层拓扑会发生变化，包括墙壁、办公桌布置和覆盖区域的改变。这些变化可能导致网络覆盖出现漏洞，当一个STA被发现在Wi-Fi热点边缘进行探测，但未能以可接受的信号水平与任何AP关联时即可识别出这种情况。然而，如果探测使用的MAC地址是随机化的，则可能无法检测到覆盖漏洞。这可能会影响覆盖质量，从而影响业务关键的Wi-Fi操作。
- **基于MAC地址的设备识别：**随机化和频繁更改MAC地址使得依赖MAC地址进行设备识别的机制失效，如策略分配、频段引导和多AP环境中的客户端连接优化。这对于具有基本网络堆栈的设备（如某些物联网对象）来说是一个重大挑战，因为寻找一种替代方法来进行可靠识别变得更加困难。

在企业环境中，部署RCM对依赖MAC地址识别和响应未授权实体或攻击的安全监控系统具有重大影响[123]。一些重要的例子包括：

- **非法客户端：**企业Wi-Fi网络的合法用户可能意外连接到未知或未管理的AP和SSID而不是公司AP，从而成为非法客户端。由于STA为每个SSID使用不同的MAC地址，跟踪这种异常行为变得不切实际。
- **攻击追踪：**攻击者旨在隐藏其身份，而使用RCM会使他们的MAC地址自动随机化，这使得在入侵检测系统的检测过程中追踪他们的活动并识别受害者变得困难。
- **移动热点：**在某些企业环境中，允许用户使用其设备作为移动热点以扩展Wi-Fi覆盖范围。此功能的允许设备列表通常受到限制。然而，如果这些设备采用RCM，则它们将无法被识别，对企业安全结构构成威胁。

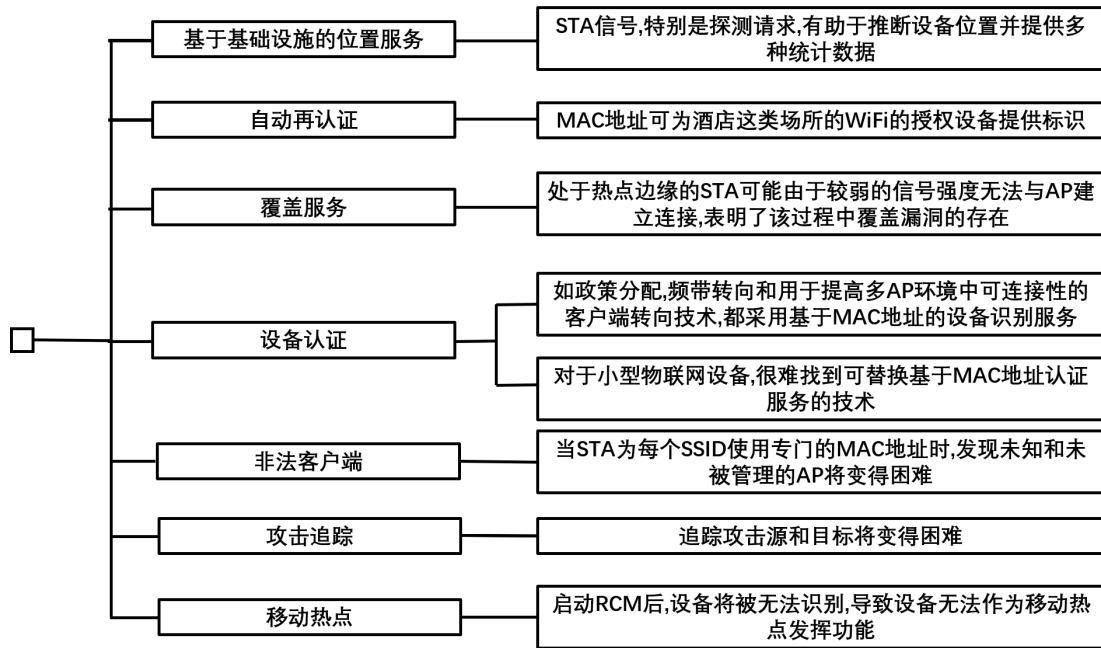


图 10. RCM对网络基础设施和用户体验的影响

这些问题与802.11操作内在相关，并对上层有影响。关于用户在RCM中的角色存在显著模糊性。虽然RCM旨在增强个人设备用户的隐私保护，但对于非个人设备（如公司提供的平板电脑或条形码扫描器），同意和隐私相关的问题变得更加复杂。为应对这些模糊性，IEEE 802.11小组于2020年初成立了RCM主题兴趣小组（TIG），最终形成了两个关键成果[124]：

- 允许厂商集成RCM（如802.11aq中所述）至少在11个用例中提出了挑战，其中依赖唯一MAC地址的功能变得复杂或不可行。一些场景需要STA识别，例如基于STA MAC地址自动检测用户相关动作（如在家或工作中调整照明或温度）或根据STA MAC地址生成支持票证。其他情况则对用户偏好保持中立，例如商店中的客流量密度测量或机场等待时间评估。然而，RCM在遏制基于不同地点和时间个体设备MAC地址检测的全球监视方面证明是有益的。认识到对唯一STA识别的需求，802.11bh小组正在努力设计一种与当前802.11网络兼容的简单替代方案来替换唯一的MAC地址。
- IEEE 802.11的最初设计没有充分考虑到个人设备共享参数的潜在隐私影响。虽然标准优先考虑了操作效率和安全性，但隐私得到的关注相对较少。结果是802.11帧中的MAC地址和各种参数可能被利用进行设备识别，引起重大的隐私担忧。为解决这一

问题，802.11bi小组的成立致力于增强802.11操作中的隐私保护。该小组旨在开发能够有效缓解协议相关的隐私风险的解决方案。

VI. IEEE 802.11 BH

如果无线MAC地址变得不可行，那么嗅探和窃听的严重性将会减弱。然而，为了确保网络能够提供正确的服务质量级别并将相关特性应用于STA,需要一定程度的合作，特别是对于STA识别。当STAs使用RCM时，识别及相关服务必须依赖替代方法，这引入了额外的复杂性。

IEEE 802.11bh专注于通过提出在客户端与网络合作背景下解决问题的方法来应对这些新的挑战。此外，该小组集中精力定义了一系列符合802.11bh目标的用例。成员们达成一致，将表III中呈现的用例纳入指定范围[125]。为向网络提供了几种用于识别合作客户端的方法。以下小节从高层次概述了这些建议。对于更详细的信息，感兴趣的读者可以参考文献[4]。

A. 已通过方案整体概览

IRM（可识别随机MAC）方案自从2021年末首次提出以来经历了多次转变。最初的方案包括一系列步骤，利用基于HMAC的提取和扩展密钥导出函数（HKDF）[126]从IRM地址（IRMA）和IRM密钥（IRMK）生成输出密钥材料（OKM）。生成的OKM表

表 III
802.11BH 范围内的使用案例介绍

使用场景	描述	案例
预关联客户端转向 Pre-association	基础设备指导设备选择以获得最高连接质量	在多频带多AP基础设施系统中,系统在扫描中跨AP和频带监视设备信号,以确定最佳服务提供商。该阶段的STA认证非常重要,并且RCM使得MAC地址作为标识符的能力失效。
在关联前/关联后访问控制(家长控制等)	控制访问基于在确保用户隐私的前提下设备识别	一般而言,目前802.11路由器的家长控制依赖于MAC地址。在MAC地址是访问终止列表(ACLs)或防火墙发挥功能的关键的情况下,RCM可能会导致该功能失效。
关联后首页自动化	802.11技术的使用是自动化系统的“骨干”	使用个人的802.11设备(如智能手机)侦测个人的行踪,可以自动化欢迎服务,如灯光,音乐等的个性化分为。一般基于MAC地址的设备识别在使用RCM的情况下会失效。
杂货铺老顾客提醒	在用户同意的情况下识别和奖励老用户	预计作为“选择性加入”,顾客同意后,允许商家获得特定用户信息(部分而非全部信息)。为了提高效率,程序必须识别顾客入口,为老顾客提供特别服务。在使用RCM的情况下,发明一种不依赖于固定MAC地址的设备识别方案十分重要。
使用随机探测的基础设备	在多AP设备中,使用RCM为每个探测在多AP和频带中转化客户端是有挑战性的	比如,已经建立连接的AP发送信标帧以引导STA在目标AP的频段上探测。目标AP从探测中收集RSSI和CS并发送到网关。网关绘制AP列表,并将其通过已关联AP BSS船速管理请求帧发送到STA。
在安全网络中检测已批准的客户端	在已批准的客户端使用RCM时,侦测他们的情况与其他后关联情况类似,都受益于802.1X的改进设备识别管理的网络安全。	在设备使用RCM的情景,包括关联前或正在探测的设备。这产生了一个问题,即设备在探测一个已知的SSID,特别是目标SSID在关联进程开始前就侦测到的SSID时,是否会使用一个类似的MAC地址。
用户支持和故障排除	识别设备技术支持	一个例子包括用户家中的设备违反策略,导致ISP检测并暂停住宅服务。作为回应,用户联系技术支持。技术人员可以定位到问题设备的MAC地址。RCM使识别变得复杂。
虚拟BSSID(跟随用户)	一个客户端设备在一个ESS的多个AP中转移时会生成一个BSSID,以监督客户端转移。	在多AP设置中, AP通过探测请求中的MAC地址识别设备,从而为无线连接创建唯一的BSSID。

示为OKM=HKDF(IRMA, IRMK), 在STA与AP关联阶段作为额外的信息元素 (IE) 共享。这种交互由于其内在复杂性获得了宝贵的反馈, 导致了一个更加简单的方案。在这个改进版本中, STA选择IRM并在4次握手 (HS) 的第二条消息中与AP共享。实际上, STA可以自由选择任意48位随机序列作为下次与相同ESS关联时的MAC地址。唯一的限制是这个MAC地址必须是本地管理的, 如前文所述。 图11展示了第n次关联和

第n次4次握手过程中IRM的一些交互, STA在M2期间通过IRM密钥传递元素 (KDE) 发送RM。作为回应, AP在M3期间发送另一个IRM KDE, 确认为下次关联预留提出的MAC地址。AP也可以使用IRM状态来选择识别下一个MAC地址。在这种情况下, STA可以选择继续关联或立即解除关联。当处理被ESS识别的STA时, IRM有效防止了第三方对STA的跟踪, 同时仍允许受信任方识别它。该方法的优势在于其简单性和赋予STA对其隐私控制的能力。

MAAD (MAC地址指定) 在802.11bh提议版本中也有所发展。最初, 它是一个异步方案, STA会异步发起一个MAAD请求作为一个动作帧, 消除对4次握手更改的需求。然而, 在其最新形式中, 共享两个新MAC地址的责任落在了AP上, 这通过4次握手的信息实现 (当前主要关注M3消息)。这两个共享的MAC地址服务于不同的目的: MAAD MAC 1旨在用于STA下次关联期间作为TA (传输地址), 而MAC 2则用于任何预关联阶段的探测, 如果STA希望被识别的话。为了防止非法AP欺骗, AP提供了额外

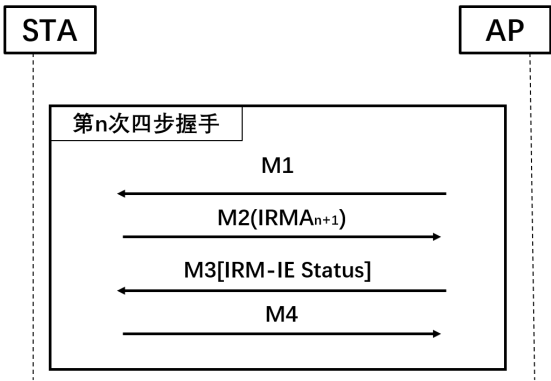


图 11. IRM系列图表

的ID以及两个MAAD MAC地址，这些信息随后包含在探测响应中。图12说明了预关联、关联及4次握手阶段的关键部分。在第 n 次预关联期间，STA使用由MAAD分配的MAC 2，而MAC 1则用于第 n 次关联请求。在第 n 次4次握手的M3消息中，AP将ID和两个MAAD MAC地址传达给STA，以便在后续与ESS的迭代中使用。

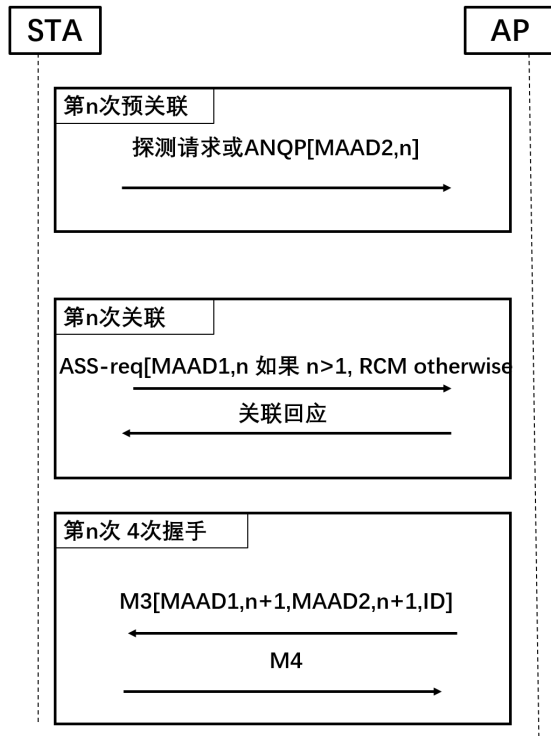


图 12. MAAD 系列图表

设备标识符（Device Identifier, DID）方案，目前被称为设备标识符（尽管有可能会被重新命名为持久不透明标识符），在4次握手过程中使用一种未指定形式的通用标识符。图13展示了与之前描述类似的“乒乓”过程。在第 n 次4次握手的M2消息中，STA利用KDE机制发送其设备ID（DID），如果STA希望被识别，该ID是在上一次迭代中由AP分配的。随后，在M3消息中，AP提供了将在下次关联时使用的不透明标识符（即第 $n+1$ 次）。由于标识符是不透明的，任何观察者都无法通过这次交换来跟踪STA。如果STA打算在下次会话中被识别，它会在（重新）关联时发送标识符（在一个不透明的KDE内）。此方案是首个被投票纳入802.11bh草案文本中的方案[127]。需要注意的是，直到STA自愿发送不透明标识符之前，它都是未被识别的。

基于规则的RCM（RRCM）和增强型e-RRCM:

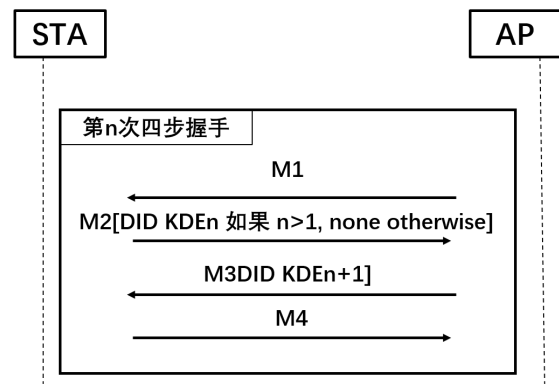


图 13. 设备标识符系列图表

基于规则的RCM（RRCM）是一个需要额外计算能力但能将STA识别范围扩展到不仅仅是下一次关联的有趣提议。实际上，这也允许STA在下次关联之前（即扫描阶段）被识别。这是通过在4次握手期间交换密钥材料，并使用种子和递增数字作为HKDF的盐来计算 N 个MAC地址实现的。这些地址可以被STA用于接下来的 N 次关联中。AP和STA使用相同的算法，使得AP能够在不通过空中交换密钥或凭据的情况下计算出STA将在下次关联（或扫描阶段）中使用的MAC地址。

在一个称为增强型e-RRCM的变体中，STA还会计算一个验证信息元素（VIE），并在后续接触（扫描或其他交换）期间发送给AP。VIE作为一种哈希形式，用来验证STA的合法性，从而减轻重放攻击的风险。使用标准RRCM，观察者可以捕获STA发送的帧并重放它，而AP缺乏机制来识别这种冒充行为。通过引入VIE，e-RRCM增强了安全性，确保了STA身份的验证，有效防止了潜在的安全威胁。

B. 802.11bh方案的分类参数

802.11bh的方案设计并不与802.11aq规则相矛盾，因为802.11bh旨在作为一个“快速修复”。因此，在关联会话期间更改MAC地址是不允许的。然而，STA保留了断开连接、更改其MAC地址并根据需要重新连接的自由。通常，所有这些方案都为STA提供了退出识别程序的选项，允许它在下次关联或预关联阶段表现得像一个新STA。

目前提出的方案展示了一些共同模式，使它们能够被分类到特定类别中。这些类别的参数总结在图14中，并在下面详细说明：1)标识符类型：STA标识符必须是一个可验证的位串。一些802.11bh上下文中提出的方案仍然使用随机MAC地址作为标识符，依

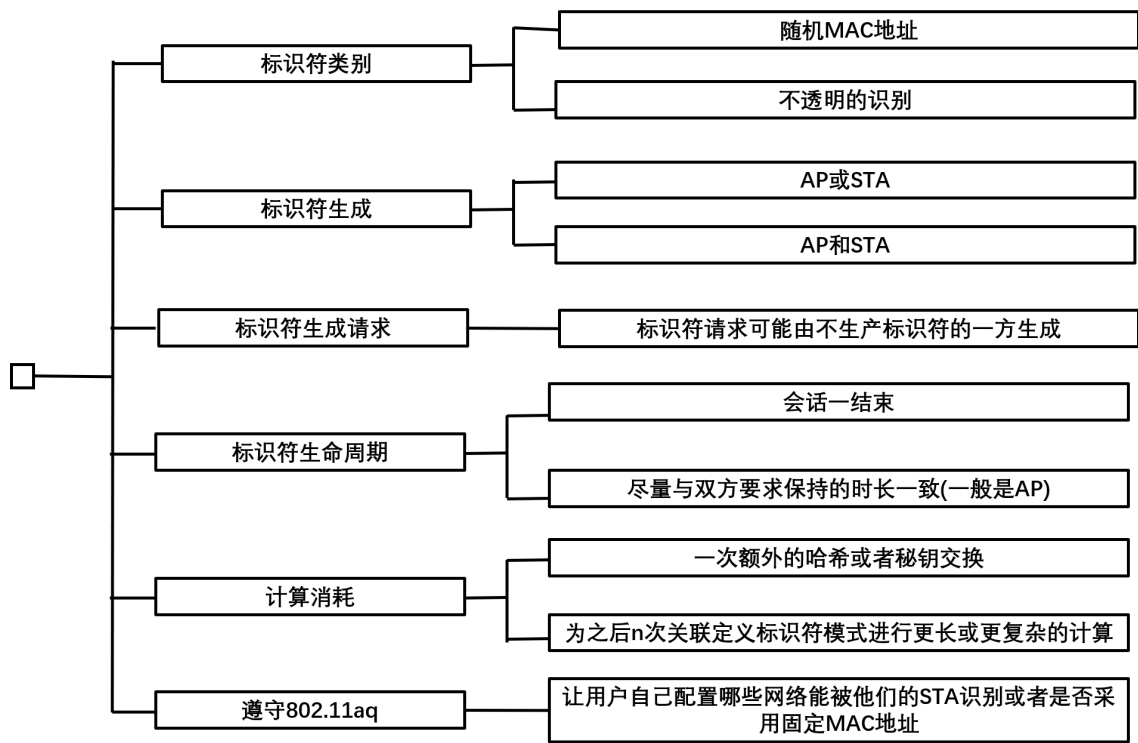


图 14. 802.11bh方案分类参数

赖于STA和AP之间的共享算法将这些MAC地址映射到身份。MAAD和IRM属于这一类。通过这些方案，STA与RCM关联，安全地与AP共享其下一个MAC地址，然后频繁地断开连接并更改其MAC地址，使得观察者更难跟踪。然而，每次AP都能识别STA，确保无缝操作。如果STA不再希望被跟踪，只需停止分享其下一个MAC地址。在其他案例(RRCM)中，下一次连接的MAC地址通过类似加密安全伪随机数生成器的算法计算得出。不仅双方都知道下一次关联的MAC地址，还可以离线计算整个序列并存储以备将来使用。这种策略减少了关联期间的计算工作量，并将一次算法运行的范围扩展到多个会话。另一类方案提出在IE的形式中使用不透明标识符。STA可以在关联过程中使用任何随机MAC地址，但可以发送IE来提醒AP其过去的身份，使AP能够在关联间追踪STA并保持服务连续性。STA仅在认为与先前关联保持连续性必要时发送IE。

2)标识符生成和触发：在无线关联中，存在一个两方关系，双方都有能力为STA确定标识符。对于AP和STA如何领导并生成标识符，提出了各种方法。在某些方案中，双方都可以参与，取决于协商或配置。这一概念的一个有趣变体决定了哪一方触发该过程：标识符请求可以由不生成标识符的一方发起。

3)标识符生命周

期：如前所述，某些标识符的生命周期非常短，意味着一旦会话结束它们就不再存在，使得任何跟踪努力变得徒劳。相反，Device ID等方法提议了一个设备标识符，该标识符通过可验证的安全签名共享，并且只要各方（通常是AP）希望维持就可以保持活动状态。换句话说，没有要求在每个会话结束时销毁它。计算成本：所有提出的方案都在关联或预关联阶段引入了少量额外的消息或计算。如果标识符的生命周期有限，计算开销仍然最小，只涉及一个额外的签名哈希或密钥交换。然而，在RRCM和e-RRCM的情况下，由于这些方案所需的扩展视野，定义接下来N次关联的计算变得更长更复杂。

5)对802.11aq的遵循：这些方案提供了不同程度的对802.11aq的遵守。它们表明，802.11bh需要在主标准中明确规定STA在何种情况下可以或应该更改其MAC地址。此文本将控制权交给用户，允许他们决定在哪些网络中STA应跨会话被识别（例如，工作Wi-Fi），以及在哪些网络中应使用稳定的（可能是内置的）MAC地址。对于其他网络，用户将配置具有缓慢变化参数的RCM方案，同时尽可能频繁地启用快速轮换（伴随短暂的断开连接），而不会中断用户活动。

表IV显示了所呈现的802.11bh方案的比较。

表 IV

802.11BH方案根据不同类型的比较,生命周期和视界根据会话数表示

参数	IRM	RRCM	MAAD	DID
ID类型	MAC	MAC	MAC	不透明
生成	STA	AP	AP	STA/AP
存活时间	1	1	1	$i=1$
视界	1	N	1	1
计算消耗	低	高	低	低

C. 802.11bh 研究困难与未来计划

802.11bh最初被构想为一个短期的小组，旨在将稳定标识符纳入802.11标准中，以解决与随机化MAC（RCM）相关的潜在风险。然而，该小组的工作遇到了预料之中的挑战，如实施复杂性、信任委托问题以及预关联发现机制的探索。

实施挑战：为802.11bh提出的基于MAC地址的方案因其简单性而在概念上具有吸引力。STA可以自行选择或根据AP建议使用MAC地址，类似于RCM和预RCM方案。这消除了需要额外信息元素（IE）来揭示STA返回网络及先前识别的需求。STA有自主权决定是否允许在关联过程中由AP通过建议或之前公布的MAC进行识别，或者在其他情况下选择不同的MAC地址。然而，实施这样的方案面临挑战。STA必须维护当前和未来MAC地址的映射，可能按SSID划分并跨越多个关联（以防止MAC重用）。如果STA决定断开并重新连接，则需要即时替换其MAC地址。目前市场上的低级驱动程序并未针对这种跟踪和快速链路层标识符交换进行优化。

依赖于IE的方案缓解了上述基于MAC地址方案的相关难题，但可能会引入具有挑战性的兼容性问题。特定IE的存在可以向攻击者发出信号，表明STA正在重新加入网络，可能帮助概率引擎将参数与先前观察到的MAC地址相关联。因此，IE的存在可能无意中为攻击者提供了额外的线索。

此外，IE格式的设计必须谨慎地适应各种场景（例如物联网、企业、零售、酒店业），其中标识符字符串可能不同。虽然开放式格式似乎为灵活性所必需，但它也引入了允许形成不正确字符串的风险，这些字符串可能被AP误解或作为特殊字符用于攻击。依赖于保护管理框架（PMF）的IE方案在非PMF网络中可能会失败。此外，使用智能值编码或加密的IE方案对STA和AP都施加了额外的计算负担，这可能无法高效扩展。这个问

题对于打算更快速更换MAC地址的STA或可能需要同时为进入同一场所的大量STA计算值的AP来说都会出现。

最终，任何方案支持隐私的能力取决于所选择的下一个MAC地址使用的伪随机数生成器（PRNG）。涉及的一方（AP或STA）所选择采用的PRNG的质量决定了上述任何方案的强度；由于PRNG不佳导致的MAC地址间任何潜在相关性都容易使这些方案出现缺陷。

复杂性：在实现这些方案时，复杂性是一个值得考虑的方面。过去的经验表明，复杂的算法往往会导致芯片组固件和软件中的次优实际实现，有时对预期的安全性造成的损害大于益处（如WPA2和KRACK攻击的情况[128]）。尽管这些问题可能归因于简单的漏洞，但它提出了一个疑问：增加的复杂性是否真正提供了显著的价值。因此，长远来看，提倡更简单且不言自明的方案可能会提供优势，增加成功采用和实施的可能性。

信任委托：信任委托的问题在于协议定义了STA的标识符，这需要仔细设计值生成过程。例如，如果低级AP总是为特定STA生成相同的标识符或可以轻易反向工程的值（例如当前标识符值加上固定索引），那么RCM的全部目的就会被破坏。因此，如果由AP生成值，则只有在生成方案严格定义且极难反向工程的情况下，STA制造商才会接受它。虽然实现这样的设计目标是可能的，但会非常耗时。

因此，让STA自己生成值可能是更好的选择。注重隐私的厂商可以实现一个强大的方案，而不依赖于802.11bh小组开发普遍接受的解决方案，后者可能需要数年时间。然而，这种方法也有其自身的挑战。AP需要接受并识别STA共享的身份值，无论是否使用PMF。无法保证AP会识别并接受STA返回的任何值，因为某些特殊字符可能未被实现或被禁止使用。

即使AP能识别格式，如果网络上的另一个STA已经发送了相同值，也有可能发生身份冲突。另一方面，如果由AP生成身份值，它可以丢弃任何已使用的生成值。但是，单独的STA无法访问给定AP上活跃STA及其标识符的列表。这种情况下，确保身份的独特性和避免冲突成为一个重要议题，同时还需要平衡方案的复杂度与实用性，以促进更广泛和有效的应用。

预关联发现：802.11bh工作组当前正在积极讨论某些导致其成立的用例的有效性，其中之一便是预关联发现。在特定网络中，特定类型的设备在关联之前需要被导向到特定频段或无线电上。例如，物联网设备可能

需要被引导至2.4 GHz AP或无线电，而AR/VR设备则需要6 GHz频段。这种导向动作在关联前至关重要，因为5 GHz或6 GHz频段中的AP可能不会响应物联网对象的探测请求。当STA在AP之间漫游并探测以发现下一个AP时，也有相同的要求。

然而，一次性RCM地址的使用并不利于此类识别。从概念上讲，预关联识别问题似乎属于802.11bh的范畴，因为它解决了RCM干扰的802.11的功能之一。需要注意的是，根据802.11aq的规定，在帧交换期间STA的MAC地址应保持静态。但是，802.11标准并没有要求AP在STA尝试关联之前就识别STA，而且标准也没有描述任何预关联导向机制。实际上，标准第11.1.4.3.4节[129]规定了相反的内容，要求AP对接收到的所有探测请求作出回应（除了几个逻辑和程序上的例外）。因此，为了导向目的而在特定频段忽略探测请求是不符合标准的，这导致了802.11bh内部关于是否应该“修复”违反标准的行业常见做法的激烈辩论。

支持该用例的人指出，某些AP会对所有探测请求作出回应，但在设备应被导向的频段内提供更快的响应，而在其他频段则延迟响应，使设备认为只有需要被导向的频段才是可用的。这种延迟响应的方法符合标准且不违反任何规则。另一方面，反对预关联识别的人探讨了使用设备MAC地址设置照明或加热水平，并可能控制其他元素如命令咖啡机或自动开门的情况。他们强调仅依赖MAC地址执行这些操作的内在风险。据他们说，即使RCM使得这些行为变得不可能，802.11bh也不应提出允许不安全行为的解决方案。然而，预关联识别的支持者指出，所提出的解决方案将专门应用于返回的STA，这些STA将利用受保护的帧来安全地建立各方的身份。这样，802.11bh可以用一个解决方案实现两个关键目标：解决“到达的MAC”问题同时解决预RCM解决方案的安全弱点。

所有这些挑战都是可以解决的，802.11bh的工作也在继续进行。最初作为一个短期实施修复的努力已经演变为对标识符的本质及其生成实体的深入分析。最后，在撰写本文时，由于所需的复杂性和与AP的协调，MAAD和RRCM方案已被放弃[127]，留下了IRM和Device-ID作为工作方法。正如前面部分所述，IRM方案已经进化成比原始方案更简单的方案，STA对其隐私拥有完全控制权。

VII. IEEE 802.11BI

802.11bi小组的明确目标是在IEEE 802.11框架内标准化用户隐私解决方案。这项任务复杂，因为许多802.11预关联发现程序，由于其能力的多样交换和支持可选功能，即使使用了RCM，也容易受到指纹识别攻击。在2020年修订的IEEE 802.11标准[129]中，允许STA发现AP并指示其支持协议以便AP定制其Probe Response的探测请求允许34个可选元素。同样地，Probe Response允许92个，认证帧允许25个，关联请求帧允许46个，关联响应允许57个可选元素。即使在关联之后，当预期交换将被加密时，帧头仍然未受保护，因为范围内的所有接收者都需要确定它们是否为预期的接收者。因此，观察者可以轻易跟踪任何网络实体与特定STA之间的对话，并从帧头中的元素或对STA地址（作为源或目的地）和帧结构（如大小或后续帧的速度）的简单观察中推断出大量信息。

解决所有这些问题可能带来挑战，特别是如果这需要重新设计整个IEEE 802.11标准。因此，802.11bi是一个庞大的项目，预计需要几年的工作时间。其初步任务是编制一份潜在隐私暴露和实现更私密IEEE 802.11标准所需前提条件的全面列表。在这个工作组努力阶段，已经确定了超过50项要求，这些要求可以归类为9个不同的组。重要的是要强调，这些仅仅是需要完成的要求和目标，实际的协议定义将在后续阶段建立。许多要求都是针对STA的，因为个人设备通常位于这一侧。专注于增强STA隐私的机制被称为客户端隐私增强（CPE）。然而，该小组还设想了AP隐私保护机制，主要基于两个原因：

- AP可以是个人设备上的软AP，例如为个人笔记本电脑提供网络共享的智能手机，或者是家庭AP。在这两种情况下，它可能与私人用户关联，并且其网络流量可能会无意中泄露用户的敏感信息。
- 即使在AP作为共享服务设备的情况下，它也与STA协同工作。在AP处观察到的通信模式可能会无意中暴露有关参与通信的相关STA的信息。因此，保护STA的隐私也可能需要同时保障AP的隐私。自然地，如果STA不也被纳入保护机制中，单独保护AP是没有意义的（如果AP是一个个人设备，几乎可以肯定连接到它的STA也是一个个人设备）。同时保护双方的要求被称为基本服务集隐私增强（BSS Privacy Enhancements, BPE）。BPE功能扩展了客户端隐私增强（CPE）功能。

图15总结了探索的不同方向。

A. 预关联保护

预关联情况对于支持隐私的802.11理念至关重要。STA和AP需要就允许它们协商关联可能性的参数达成一致。STA可能仅向AP传达标准化参数，这些参数足以让AP知道如何响应STA（例如，STA能理解哪些协议和数据速率，而不表达任何特定的额外能力）。这种简化是一个明显的改进，可以减少STA的隐私暴露，因为大多数STA可能会表达相同的支持。然而，仍有两个难题需要解决：

- STA可能需要表明对特定选项的支持。在许多情况下，这种支持不会改变STA是否关联的决定，只是表达了STA期望或希望的服务。在这种情况下，支持可以在关联后通过PMF进行协商。然而，在其他情况下，对可选功能的支持可能是STA是否决定关联的前提条件。一个典型的场景是运行延迟敏感应用（如Wi-Fi启用的AR/VR头戴设备）的STA位于信号水平相当的两个AP范围内。然后，STA可能希望查询AP对QoS参数的支持，以决定哪个AP更有可能提供良好的用户体验。提出QoS参数的要求对于关联决策是必要的，但可能会暴露有关STA的信息。一个可能的方向是创建一种关联状态，其中STA可以加入多个AP（在当前的IEEE 802.11标准中，STA一次只能与一个AP关联）。STA可以使用这个安全链接在选择停留在其中一个AP并开始其数据流之前协商额外的参数。这样的机制相比现有的关联编排会增加一些开销（因为STA需要与两个AP协商密钥），但好处可能超过成本。
- 对于802.11be/Wi-Fi 7多链路操作（MLO），STA可以建立到一个AP的两个链路。在标准的当前版本中，STA可以在一个链路上宣布其多链路标识符，使得任何观察者都可以将单独的链路映射到相同的STA。换句话说，观察一个链路可以使窃听器识别出STA正在使用的另一个链路。一个可行的解决方案可能是修改多链路协商结构，并规定STA和AP必须在第一个链路上通过单播和加密帧协商第二个链路参数。

B. 重关联保护

如第二部分所述，802.11关联过程在STA通过被动或主动扫描建立了潜在AP列表之后，从身

份验证阶段（图6中的步骤1）开始。目前，所有STA和AP都实现了整个关联过程，尽管身份验证阶段仍有很大的讨论空间。STA不太可能只实现其中的一部分，从而使身份验证阶段变得冗余。802.11ai-2016[130]修正案试图通过使用此阶段有效协商认证密钥来增强这一过程。然而，在没有该修正案的情况下，身份验证阶段往往类似于视频会议中的对话，一方说“早上好”，另一方回答“你也早上好”，然后第一方问“你能听到我吗？”（显然这是肯定的，否则不会给出回复）。

同样地，STA可以启动关联阶段，并将未收到响应解释为STA未遇到有效的802.11帧的指示。然而，一个关键问题在于这种交换缺乏加密，从而暴露了STA和AP的参数。在实施WPA2或WPA3的网络中，4次握手（HS）生成PMK，由成对主密钥标识符（PMKID）标识，它唯一地代表一个密码或口令而无需通过空中发送其实际值（本质上是“我们使用的是编号为64的密码”）。当STA暂时离开网络并在返回时携带重新关联请求时，这个标识符非常有用，允许STA直接声明“我现在回来了，将使用编号为64的密码”。因此，AP立即知道如何解密STA流量，STA也隐式地验证了其之前的正确认证作为合法客户端。

鉴于当前身份验证阶段的有限优势以及关联阶段缺乏保护，这种编排显示出老化迹象。因此，主要需求之一是通过将身份验证阶段转变为真正的身份验证过程来增强这些交换的安全性。这涉及到执行802.1X/EAP交换，促进STA和AP之间的相互身份验证和密钥推导，如图16所示。因此，在身份验证阶段结束时提供加密密钥。随后，关联阶段及其交换的一系列参数就可以得到保护。此外，由于在此阶段完成身份验证，STA也会确认自己正在与一个真实的AP通信（而不是伪装成AP的攻击者），进一步降低了第三方企图通过冒充网络中的另一个AP收集STA参数的风险。通过修改身份验证程序，可能可以在STA返回时模糊其共享的连接标识符。设计上，每个STA-AP对的密钥都是唯一的。无论是从热点范围共享的密码派生的操作密钥，还是其他机制如SAE和STA特定的身份验证（使用802.1X/EAP），这一点都成立。在所有这些情况下，STA在重新关联时共享PMKID或SAE标识符，通过监控PMKID或SAE ID很容易识别出漫

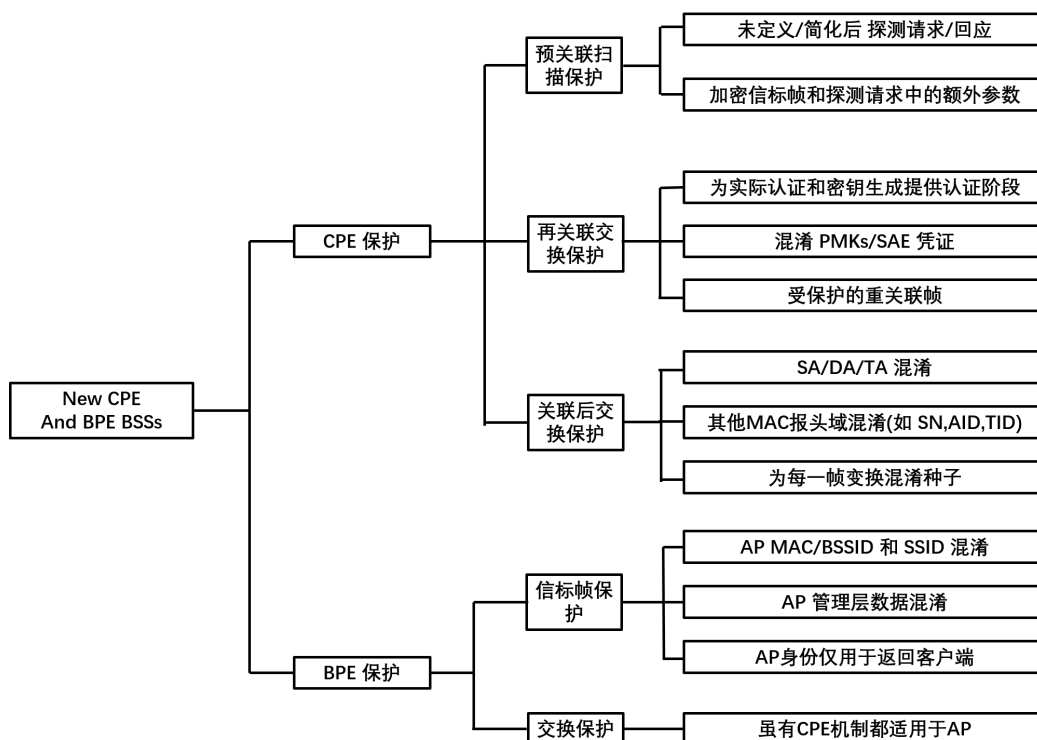


图 15. 802.11bi 需求组

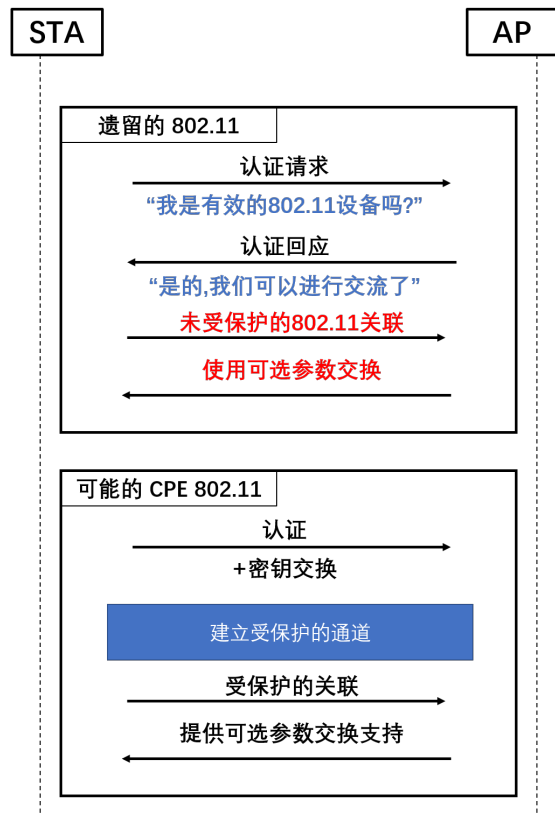


图 16. 802.11bi:使用改进关联替换遗留设计

游的STA。虽然标识符不会危及STA的安全性，但它确实能唯一地识别STA。然而，通过修改身份验证阶段，可能以某种方式在重新关联期间混淆PMKID或SAE ID，从而隐藏STA的信息不被窃听者知晓（包括STA正在返回网络的事实）。

C. MAC头部字段保护

在传统的802.11中，头部未加密，使得交换的表面可见，但内容不可见。这个决定是由于802.11协议长期历史的结果。过去，在WEP中，头部包含了接收者解密帧负载所需的关键元素。随后在802.11i-2004[131]中引入并在2007年纳入主标准的机制旨在增强负载保护，但设计时考虑了向后兼容性，导致头部仍不受保护。通常所说的WPA2和WPA3的密钥材料通过使用EAPOL协议的4次握手消息交换。换句话说，这些信息成为数据MAC帧负载的一部分，并插入到头部QoS字段之后。

如今，让RA保持明文是有意义的，这通常对应于地址1，因为这种可见性对于所有STA开始接收帧、读取头部并在RA不是其自身地址时停止是必要的。然而，如果RA是它们的地址或组播/广播值，则继续读取帧至关重要。尽管如此，如果没有观察方不是RA相同的SA（源地址）或DA（目的地址），则他们没有任何正当理

由知道这些地址。此外，帧的帧控制部分仅对正确的接收者相关，应保持对其他人的私密性。

因此，一种方法可能涉及加密这些元素以使其模糊化。然而，这种广泛的变化可能会引入向后兼容性问题，导致创建只有CPE/BPE（如前所定义）设备才能操作的新网络。对于包含不知晓隐私保护增强的传统设备的混合网络，一个更简单（尽管效果较差）的方法可能是仅仅模糊化STA-AP对之外的任何地址。对于上游流，根据需要RA是可见的，但DA将由一个模糊化的标识符表示，类似于MAC地址，STA和AP会通过受保护的初始交换达成一致。

理论上TA和DA也可以被加密。然而，在实践中，AP可能对每个关联的STA都有不同的密钥，并且需要知道使用哪个密钥来解密流量。因此，需要有关发送者的某些信息以便AP选择正确的密钥。最简单的方式是让TA保持可见。

另一种方法可能涉及使用某种形式的帧序列号预测，允许AP从头部的值推断出哪个STA发送了帧，而无需向观察者揭示编号方案。对于下行链路流量，SA也会使用模糊化标识符，从而隐藏STA通过AP通信的设备。

当STA需要漫游到另一个AP时，IEEE 802.11r（快速转换，FT）使STA能够在完全切换连接之前与下一个AP预先协商密钥和其他参数。这种预防措施允许STA在连接到下一个AP时立即开始传输和接收数据，而不浪费时间协商凭据。根据STA使用的FT类型，它要么与其当前AP通信，指示目标下一个AP的MAC地址，要么与下一个AP通信，指示其当前关联的AP的MAC地址。在这两种情况下，这些MAC地址都应被模糊化以保护隐私。

除了MAC地址外，第三部分中识别的其他元素也应受到保护。其中一些可以通过将其集成到加密头部中进行模糊化处理，例如帧序列号、STA用于指示其注册号码（作为此特定会话中AP上的客户端）的关联ID（AID），或者指示数据帧所属的QoS类别的流量标识符（TID）。这些元素存在于许多帧中。再次强调，不清楚为什么应该允许任何观察者知道另一个STA的AID或特定STA是否在发送语音对比视频流量。

另一方面，有些元素难以通过加密进行模糊化，因为它们位于MAC层之外。这是用于生成均匀分布比特的不相关二进制序列的加扰函数的情况。该操作允许相同的数据负载映射到不同的二进制序列（以及物理

信号）。然而，一些设备实现简单的确定性算法来为加扰器播种，例如连续地从帧到帧运行加扰器种子而不重置或每发送一帧就将种子增加一[21]。这些简单的加扰器实现为攻击者提供了信息，并允许重新识别发射器，即使更改了MAC地址或假名。一个好的机制可以设计为每次帧随机改变加扰器种子，以增强隐私保护。

D. 受保护的管理帧

在802.11w修正案[9]批准后开发的许多管理帧在存在冒充风险可能导致用户不良体验的情况下，获得了PMF（Protected Management Frames）保护。然而，许多其他管理帧仍然未受保护，因为AP冒充的风险或后果非常有限，或者管理帧是由STA发起的。尽管如此，这些帧仍可能揭示有关STA的信息，并有可能辅助对其进行指纹识别。

例如，在多用户传输或波束成形的情景中，AP可能会通过信道的一个代表性子集向STA发送测试（探测）帧，STA会返回一个矩阵，显示信号是如何被接收的。这些信息使AP能够确定STA的最佳波束成形策略，或识别哪些STA可以被分组在一起。观察者可以利用这些帧获取关于STA距离AP的距离、其移动模式及其环境稳定性的见解，从而可能推断出STA如何接收AP信号的细节。此外，如果AP将STAs分组在一起，它们会被分配一个组ID，STA也可以在请求时返回这个组ID，再次泄露有关STA的信息。因此，保护这些管理帧以避免信息泄露并保持隐私变得至关重要。没有令人信服的理由让所有观察者都能看到这些管理帧，这促使IEEE识别了一组共10个应加密以提升隐私和安全性的管理帧。

E. AP及其信标

AP可以被视为BPE，因为它要么是个人设备，或者至少是需要隐私保护的设备。虽然家庭AP或运行在智能手机上的软AP的情况显而易见，但在企业场景中，AP也被视为私有资产，企业可能不希望将详细信息暴露给外界（例如，街上路过的人）。在这种情况下，上述提到的许多元素（RA/DA、头部的其他部分、序列号等）可以以类似于客户端的方式进行保护。

一个重大挑战源于IEEE 802.11要求AP无线电每秒多次广播信标消息，这些消息宣传AP的存在及其参数。此消息至关重要，因为STA在尝试连接之前需要检测到AP的存在。在802.11标准存在的25年里，每个

新修正案都向信标引入了额外的信息元素(IEs)，通知经过的STA关于新支持的能力。在2020年的标准版本[129]中，描述了AP必须或可以指示的近80种不同能力。从STA隐私的角度（CPE上下文）来看，确实更希望STA提出一般性问题（“你支持哪些功能？”），然后由AP在探测响应中提供细节。更好的做法是允许STA被动监听并在下一个AP信标中接收支持的功能列表。

当AP本身成为需要隐私保护的對象时，这种逻辑自然会停止。在这种情况下，有必要将STAs分为两组：那些返回AP的（例如，下班回家的智能手机），以及那些首次发现AP的（例如，尝试连接朋友家Wi-Fi的智能手机，在此之前从未访问过）。第一种情况中，一种潜在的保护措施可能是缩短信标，仅传达基本信息（例如，AP支持的基本数据速率，这也很可能被任何其他AP支持），并附带一个返回客户端在先前关联期间获得的密钥。该密钥随后可用于推断或计算额外的元素。另一种选择是加密信标的“不平凡”部分。

第二种情况提出了更难解决的问题，因为用户期望看到网络名称（SSID）列表。然而，如果SSID是唯一的或可识别的，它本身就可能构成敏感信息。在这种情况下保护AP隐私的目标已在小组要求中得到解决。尽管如此，不同的使用案例可能需要区分，以确定适用于每个场景的适当保护类型。

AP MAC地址代表了另一个受热烈讨论的元素。即使信标不再披露敏感信息，AP MAC地址的持久性质仍能实现指纹识别。这个问题不仅对家庭和软AP明显存在，而且扩展到了更大的网络。许多由私人实体管理的公共场所成为众包努力下的地图绘制目标，据称是为了帮助室内导航（尽管这种主张的可信度经常受到质疑）。然而，这种映射是在场地所有者未同意的情况下发生的，从而暴露了他们私人网络资产的身份和位置，导致了各种复杂情况。因此，建立了一项要求，即允许AP MAC地址在任意间隔内更改。然而，这种机制需要精心设计，以确保已连接的STAs的体验不受影响。

F. 802.11bi研究挑战与未来方向

IEEE 802.11bi倡议承担了一项重大任务。在需求识别的初始阶段，小组意识到在实施隐私措施的同时保留“旧”的802.11操作模式是不可行的。当前的标准优先考虑效率和参数协商，这使得在不中断通信的情况下停止STA和AP之间的信息交换变得不切实际。因

此，决定设计两种新模式：CPE，专注于保护STA隐私；BPE，旨在同时保护STA和AP的隐私。这些新模式对于有效应对隐私挑战至关重要。

然而，做出这样的决定仅仅是第一步。实际上，构建所有元素都被模糊化的新模式几乎没有难度。本质上，这个阶段涉及确定哪些元素必须保持未加密状态，例如数据帧的RA MAC地址。帧需要一个加密安全的元素来仅向接收者（无论是其中一个STA还是AP）提示发送者的身份。这使接收者能够解密其余的头部和负载，从而有效地将交换从其他各方隐藏起来。但是，观察者仍可能采用模式识别来辨识对话的某些方面，例如识别以规律间隔传输的小帧作为语音包。小组可能会借鉴其他小组的工作，如IEEE 802.1Aedk[132]，在必要时实现填充和空载荷以进一步模糊交换的内容。这种结构对传统STA来说是不可理解的，但802.11熟悉解决此类挑战的方法。类似的情况出现在引入802.11n（带有非802.11n STAs）、802.11ac、802.11ax等标准时。在所有情况下，PHY前导码指示传输持续时间，允许传统STA在包含超出其理解内容的传输期间等待。

当考虑到预关联场景时，方程变得更加复杂。在AP作为共享服务设备的情况下，STA可以被动监听信标。标准已经考虑到含有基本数据（如支持的通信数据速率）的较短信标的概念，AP可以更快地间隔发送（例如，每20毫秒一次），以最小化STA在每个感兴趣频道上的停留时间。此外，STA可以利用RCM发出一般性发现问题，采用所有STA的标准格式。然而，如果AP本身就是个人设备，挑战变得更加严峻。对于习惯网络（例如，家庭网络），一种潜在的解决方案可能是AP和STA同意共享密钥。当STA返回时，它可以接收一个带有加密标签的短信标，该标签被识别为来自家庭AP。另一方面，其他STAs可能会听到从未知且动态变化的MAC地址发送的短信标，只有明确的信息表明支持基本的数据速率。任何其他信息，如SSID或其他支持的参数，都将被加密，并且仅由返回的STAs解密。

这种优雅的方案，然而，留下了一个未解决的新STA的问题。当一个新的STA被邀请到一个运行BPE AP的网络时，它缺乏发现AP支持参数甚至SSID的方法。一种选择是让网络所有者“开放”AP通信（移除加密），但这个方向并不十分有希望。将标准限制的责任转移到用户身上并不是一个健全的技术设计，可能会导致各种问题，例如用户忘记“关闭”通信或误解

“开放”或“关闭”的含义。最终目标是创建一个“即插即用”的网络，而不是需要用户执行多个任务才能建立连接的网络。尽管存在如Wi-Fi联盟EasyConnect程序[133]这样的工具，使得带有现有网络参数的STA能够将这些参数传递给新的STA，但是采用这样的工具将需要改变数十亿用户连接Wi-Fi的方式，并且没有明确承诺提供更简单或自动化的体验。

该方案还提出了混合网络的问题。过去引入新PHY速率（在Wi-Fi联盟中被称为代际术语，如Wi-Fi 4、5、6等）的修正案由于向后兼容以前的版本而迅速被采纳。虽然Wi-Fi 5 STA无法达到Wi-Fi 6的通信速度，但Wi-Fi 6 AP支持Wi-Fi 5的数据速率。当Wi-Fi 6 STA与AP通信时，其前导码会告知附近的Wi-Fi 5 STAs传输持续时间，即使Wi-Fi 5 STA不理解传输的内容也无关紧要。然而，在任何给定时间，任何Wi-Fi 6设备都可以回退到Wi-Fi 5模式以与Wi-Fi 5 STA通信（其能力在发现消息中表达并被所有人理解）。相比之下，期望BPE AP在附近有传统STA时回退到传统模式是不合理的，因为这样做会暴露个人信息（PII）或支付卡行业数据安全标准（PCI），从而破坏保护机制的目的。同样的挑战对于STA来说仍然没有解决：它不应该在发现兼容CPE的AP时保护所有帧，然后在发现传统AP时暴露PII或PCI。这一方面代表了IEEE 802.11bi工作中最复杂的一个挑战：有效应对超出纯粹绿地场景的各种使用案例。

目标是在这样的环境中实现BPE和CPE的共存，同时有效地缓解潜在的隐私暴露。随着每年大约有30亿台新的Wi-Fi设备进入市场，以及接近5亿个热点，Wi-Fi已成为各行各业中的关键因素，需要考虑的使用案例、极端情况和例外情况的数量是惊人的。一旦802.11bi小组设计出主要的绿地机制，解决混合网络的挑战可能需要数年的专注努力。过去的经验表明，选择不对向后共存性进行处理会导致复杂性的增加，并显著延长采纳过程，这是IEEE 802.11工作组和Wi-Fi联盟在过去偶尔探索过的一条路径。

VIII. IETF MADINAS

802.11bh和802.11bi专注于解决OSI模型中802.11操作的前两层（物理层和数据链路层）的关键问题。MAC地址本身是MAC子层的一个构造。然而，隐私问题集中在用户层面，这超出了物理层和MAC层的范围。同样，攻击者作为人类实体，并不受这些层的结构限

制。此外，MAC地址在诸如DHCP、路由等多种高层服务中扮演着重要角色。因此，802.11采取的方法不太可能完全评估并解决隐私和RCM挑战。

为了涵盖更广泛的高层和服务范围，IETF于2020年成立了MADINAS工作组[5]。该小组的目标是在三个领域发布建议：

- 列出可能受到RCM地址使用影响的高层服务，特别关注由IETF RFC、最佳实践或其他IETF文档定义或管理的服务。
- 评估为这些服务使用替代STA标识符的可行性，可能消除对RCM缓解的需求。
- 评估无需识别即可提供某些服务的可能性。这项调查针对的是那些仅因为地址可用而使用MAC地址作为身份识别的服务，尽管这些服务本质上不需要任何形式的身份验证。

小组正在积极审查大量的IETF RFC以确定哪些服务可能易受RCM影响。同时，已经发布了两个初始文档来支持这一努力。第一个文档[112]提供了主要STA和操作系统供应商实施的当前RCM方案的全面汇编。为了确保这些信息的持续相关性和适用性，小组选择在Github上维护此文档[122]，从而最小化已发布RFC过时的风险。

第二个文档作为一个综合框架[134]，在指导小组的持续努力方面发挥关键作用。围绕RCM和隐私讨论中的一个突出挑战来自于使用了泛化且脱离上下文的陈述（例如，“我不希望‘他们’监视我的设备流量”）。为应对这一挑战，该文档旨在为这类陈述提供一个强大而精确的背景。其目标是澄清涉及方的身份（“我”和“他们”）、定义“监视”的范围和含义，并阐明为什么在各种场景中流量的可见性被视为有问题的具体原因。通过深入探讨这些问题的上下文依赖性，小组旨在建立对无线网络中与RCM相关的隐私问题更加细致和准确的理解。

为了更清晰地理解设备流量交换，第二个文档概述了个人设备流量可能发生的具体环境，包括家庭设置、企业环境以及公共场所。文档强调了用户在这些环境中可能放置的不同信任水平。通过分类和分析这些不同的环境，文档促进了对与无线网络中个人设备流量相关的信任动态和隐私影响的更全面理解。

在公共场所，信任度显著降低，因为任何靠近的人或访问AP或局域网的实体都可能被视为潜在的窃听器，导致在保护隐私方面几乎不存在信任。对于企业环境，

信任水平通常较高，特别是对企业提供的设备而言，因为它们传输的流量是非个人的。然而，当个人设备被带入企业网络时，信任度可能会下降，因为这些设备可能同时携带与工作相关的和个人的流量，从而在维护隐私方面产生不同的信任水平。

通过分类和分析这些不同的环境，文档有助于更全面地理解与无线网络中个人设备流量相关的信任动态和隐私影响。

同时，信任不仅涵盖了设备传输和接收的流量类型；它还包括潜在窃听者的身份。框架文档包括了一个可能获得流量可见性的参与者综合列表。值得注意的是，这些参与者既包括与人相关的实体也包括网络功能实体。例如，处于无线信号范围内（空中）、局域网上甚至互联网上的个人都是潜在的观察者。此外，网络管理员和经理也属于这一类，在某些情况下，他们不仅期望能够查看流量，也可能需要这样做（例如，帮助客户解决问题或满足法律要求）。在这种情况下，隐私问题涉及复杂的领域，包括用户同意和遵守反盗版法的问题。

令人鼓舞的是，许多国家的立法者正在积极努力建立框架来解决这些问题，大约世界上半的地区已经实施了与隐私相关的法律。然而，这些法律从一个国家到另一个国家的变化仍然是一个挑战。文档在这个领域采取了中立立场，承认MADINAS不能解决或操作于这个监管空间内。相反，它强调了一些监管区域可能强制要求访问特定流量，而其他区域则可能不会，并强调了仔细观察和识别这些不同的法律景观的必要性。通过详细说明各种参与者及其角色，框架文档使得对无线网络隐私方面的复杂性有了全面的理解。

文档还全面考虑了网络功能实体。这类实体包括在数据链路层运行的设备，如接入点（AP）和交换机，以及专注于RCM并在高层运行的设备，如路由器和高层服务。MADINAS明确将这些元素定义为其范围内的组成部分，而不对其追踪单个设备MAC地址或查看相关流量的角色表示任何偏见。相反，文档提出了一种库存方法，系统地列出使用MAC地址（或携带的流量）的系统和服务、它们被使用的具体目的，以及RCM是否对其功能构成任何挑战。此外，文档评估了现有机制是否有合适的替代方案，提供了关于在保留基本网络功能的同时解决隐私问题可能性的客观评估。

A. MADINAS 研究挑战与未来目标

在撰写本文时，已有超过9000份RFC（请求评论文档），其中一些部分被其他文档更新，且许多与MADINAS的关注点无关。梳理这一庞大的集合并进行分类是一项耗时的任务，而遇到的服务的多样性使其更加复杂。以DHCP为例说明这种复杂性：DHCP的操作由多个RFC管理，主要是RFC 2131 [135]，以及RFC 951 [136]、3396 [137]、4361 [138]、5494 [139]和6842 [140]。DHCP协议最初设计时预期一个MAC地址严格对应一个设备，在RCM（减少连接模式）出现之前。因此，该服务被构架为在特定时间段（从几小时到几天不等）分配具体的IP地址。然而，当DHCP客户端在网络租赁期满前离开网络时，DHCP服务器检测这种离开的能力有限。虽然理想情况下，客户端可以发送一条消息（DHCP释放）来释放IP地址，但许多客户端要么忽略此步骤，要么由于操作限制无法发送该消息。因此，DHCP服务器通常会保留为该客户端（与其MAC地址关联）预留的地址直到预计再次通信进行地址续租。

此外，当租赁期满后返回时，如果客户端记得其在网络中的先前地址，则可能请求分配相同的IP地址。如果没有其他STA被分配该IP地址，DHCP服务器通常会同意这样做，因为这有助于无缝恢复客户端会话。

显然，使用RCM并且频繁断开和重新连接的新MAC地址的客户端可能会引发两个不同的问题。首先，单个客户端可能会耗尽DHCP池中的所有可用地址，从而过度占用服务器资源。一种潜在的解决方案可能是要求客户端在RCM期间发送DHCP释放消息以释放IP地址。然而，在公共场所，个人设备可能不信任基础设施的一部分，并试图隐藏其MAC地址轮换，客户端可能不会向网络发送如此明显的线索。其次，客户端可能更改其MAC地址但仍请求分配相同的IP地址以保持会话稳定性。然而，从服务器的角度看，新的MAC地址代表一个新的客户端，它无权声称已被分配给另一STA的地址。为解决这些挑战，一些MADINAS成员建议缩短DHCP租赁期限。然而，这种方法引入了新的复杂性，例如对于尝试通过进入睡眠模式来节省能量的电池供电客户端可能出现的问题，以及服务器面对超出其设计处理能力的大规模续租请求的问题。尽管DHCP服务可能包含缓解因RCM引起的问题的规定，但在实际实现中，这些规定可能无效。此外，DHCP服务包含的选项可能与RCM的隐私目标相冲突。例如，客户端可以在其消息中包含客户端标

标识符字段，用于多种目的，如提供客户端特定选项、声明客户端站组成员资格（并相应地获得自定义访问权限），或者简单地将机器映射到用户。当一个STA发送像“Jerome的电话5559131”这样的标识符，轮换了其MAC地址，然后用相同的标识符请求新地址时，有很大的可能性这是同一个客户端，而不是两个偶然共享相同标识符的设备。在这种情况下，制定明确的建议被证明是具有挑战性的，因为这些建议很大程度上依赖于特定环境，而且STA上的DHCP客户端独立于Wi-Fi驱动程序运行，缺乏对操作环境的认识。因此，仅解决DHCP问题预计就是一个漫长的过程，而DHCP只是众多利用MAC地址或以某种形式遇到RCM相关挑战的协议之一。

到目前为止，小组已经识别出几十个类似的协议，每个协议在不同的领域内运作，并由于其概念和设计早于RCM而面临挑战。这些协议中可能包含与RCM目标相矛盾的规定，而其他协议可能提供部分解决方案以支持在RCM驱动的世界中运行。然而，这些规定可能在现实世界中并未被广泛使用，或者它们的实施可能会显著影响服务器和支持网络的结构和可扩展性。因此，解决由RCM影响的各种协议所带来的复杂性需要一种全面且谨慎的方法。

MADINAS小组在其持续的努力中保持坚定不移，但预期的结果可能是产生一套全面的建议，这些将从根本上改变当前的网络格局。这些建议预计将深刻影响行业实践以及客户端和服务端端的实现。因此，考虑到小组发现所提出的重大变化，采用这条路径预计将是漫长的。

IX. 最终结论

A. 经验

在IEEE 802.1和802.11的讨论中，强调了MAC地址在网络会话期间保持唯一性和稳定的重要性，以确保连接性和相关服务。然而，智能手机使用的快速增长揭示了通过MAC地址无意间披露个人信息的问题，促使重新评估隐私影响的讨论。最近来自Wi-Fi网络部署的反馈强调了需要明确的指南来保护网络会话外客户端站身份的用户隐私。

从分析RCM引入的问题中学到的教训表明，达成一种标准化方法的重要性，在这种方法中，隐私增强与网络稳定性之间需保持平衡。对各种网络参数的仔细考虑对于避免潜在的身份识别漏洞至关重要。RCM还

对安全监控系统有影响，妨碍了对流氓客户端和攻击者的追踪，并识别用作移动热点的设备。

一个重要教训是标准化工作的缺乏协调导致不同操作系统和设备供应商之间的MAC地址生成和管理存在差异。这表明需要一个标准（IEEE 802.11aq）提供关于生成随机MAC地址的政策建议，包括每个网络、每个周期和每个会话的选项。然而，更激进的MAC地址管理策略并未明确涵盖，这在某些情况下提出了挑战。激进的MAC地址随机化可能影响各种网络服务，需要替代的身份识别方法。从中得出的教训是不同的方法提供了不同级别的隐私和跟踪阻力，允许STA选择符合其需求的身份识别方法。

在实际应用中，简单且自明的方案可能更有益，避免了复杂算法可能导致的次优结果。在设计IE格式时应考虑物联网、企业、零售和酒店等多种使用案例，以适应不同的标识符字符串。标识符的价值生成过程必须定义良好且能抵抗逆向工程，以维持RCM的隐私目标。寻求简单而有效的方案推动了802.11bh中的讨论，最终将可能的方法缩小到最直观的几种。

通往802.11aq的经验促成了802.11bh技术组的建立，旨在为解决由RCM引起的问题达成普遍接受的解决方案。该小组的讨论提供了一个重要教训：802.11网络中的隐私保护需要一种全面的方法，涵盖各种交换、头部保护，并考虑STA和AP的隐私问题。在保持通信效率的同时平衡隐私保护提出了挑战。不同的使用案例和场景需要定制化的隐私保护机制。

接下来的进化步骤是扩大无线局域网（WLAN）中隐私问题的范围。IEEE 802.11bi倡议激发了关于WLAN中隐私问题的讨论，这一讨论得出的经验教训指出开发两种新模式——CPE和BPE的必要性。这两种模式分别针对STA和AP的有效隐私保护而设计。设计这些模式涉及到在确保通信效率的同时混淆某些元素。在此过程中得到的一个重要教训是如何应对处理混合网络的挑战。众多使用案例和不断扩展的Wi-Fi设备市场带来了显著的复杂性。解决混合场景中的向后共存问题至关重要，尽管这可能需要相当多的时间和努力。过去的经验表明，忽视向后兼容性会导致复杂性和采用延迟。

相反，对隐私问题的分析显示，向后兼容性增加了必须实施的替代程序的数量。关于隐私问题的讨论提出了是否应该放弃旧的实现，转而支持能够解决当前网络环境中过去问题的新解决方案的问题。在某些网

络场景中，仔细评估绿地方法（greenfield approach）是必不可少的，以避免为了保持向后兼容性来满足少数客户端的需求而牺牲性能。

随着MAC地址周围隐私问题的兴趣增加，显示出这些问题超出了物理层和MAC层，需要考虑高层和多样化的网络服务。从中得到的教训是，不同环境（如家庭、企业、公共场所）需要根据各种因素对信任和隐私暴露进行细致评估。

隐私问题的复杂性源于潜在窃听者的身份，包括与人相关的实体和网络功能实体。RCM对DHCP影响的分析代表了一个重要的考虑教训。实际上，对该问题的深入分析揭示了资源管理和会话稳定性方面的不同问题，强调了在保持基本网络功能的同时实现隐私目标的复杂性。从中得到的教训是，解决与RCM相关的挑战需要仔细考虑特定环境和网络协议的实际世界实施情况。

B. 挑战与未来方向

在802.11aq修正案中包含隐私澄清是朝着解决与MAC地址随机化相关的隐私问题迈出的积极一步。然而，一个主要挑战在于缺乏这种做法的标准术语，因为不同的供应商采用不同的命名惯例。未来的努力应集中在建立一个广泛接受的术语，如RCM，以促进对隐私保护技术的统一理解和实施。

需要进一步的研究和标准发展来应对更为激进的MAC地址随机化策略，并全面规范其实施。探索STA中的位置感知机制以区分不同的网络可能有助于提升隐私实践。IEEE 802.11aq标准为MAC地址管理提供了宝贵的指导方针，赋予STA灵活性选择平衡隐私和网络稳定性的不同策略。该标准代表了鼓励在此领域继续研究的第一步，以改进隐私措施。

基于此标准，IEEE 802.11bh技术组和IETF MADINAS工作组已经启动了旨在识别需要修订的一组第2层服务（前者）和高层服务（后者）的活动，以解决激活RCM带来的问题。此外，IEEE 802.11bi技术组已经开始着手调查Wi-Fi网络中与隐私问题相关的难题和议题。

802.11bh：表V总结了由IEEE 802.11bh技术组活动提出的主要研究挑战。随着研究的深入，对标识符的本质和生成进行了更深层次的分析，超出了该技术组的初始短期目标。纳入稳定标识符以解决与RCM相关的风险提出了若干研究挑战和未来工作的机会。

主要实施挑战之一是基于MAC地址方案的固有复杂性。设计既能有效保护隐私又能抵御潜在攻击的身份验证机制是一个重大障碍。确保强大的安全性和与现有系统的兼容性之间需要找到微妙的平衡。此外，与IE的兼容性问题也给整合稳定标识符带来了挑战。研究人员必须解决特定IE方案相关的计算开销，同时确保与IEEE 802.11标准的平滑互操作性。在高效计算与遵守标准化协议之间找到正确的平衡对于成功实施至关重要。

另一个关键挑战在于标识符生成的信任委派。决定是由AP还是STA负责安全值生成需要仔细考虑和强有力的安全措施。这一选择对隐私、认证和系统整体完整性都有影响。

探索关联前发现机制引发了关于在关联前如何安全识别设备的辩论。虽然支持者强调处理返回STA的安全解决方案的必要性，但为关联前识别设计高效且保护隐私的方法仍然是一个持续的挑战。在安全性和效率之间找到平衡对于确保Wi-Fi网络中无缝且安全的通信建立至关重要。

802.11bi：由802.11bi技术组进行的初步分析揭示了不同关联前发现程序对指纹识别的脆弱性，强调了解决STA和AP隐私问题的重要性。此外，分析还揭示了项目的广泛范围，确定了超过50项隐私增强要求，特别关注CPE和BPE，以保护STA和AP的隐私。

任务的复杂性得到了充分认识，预计完成这项工作的时程跨度为数年。这个时间框架证明了为实现Wi-Fi网络强大且保护隐私的解决方案所需的彻底性和努力。表VI中列出的研究挑战集作为一个指导框架，旨在应对隐私意识用户不断变化的需求，并保护敏感信息免受未经授权的访问。在802.11网络背景下，关联前保护在促进隐私方面起着关键作用。为了促进STA和AP之间的关联协商同时减少STA隐私暴露，可以通过参数的标准通信来简化这一过程。然而，这种简化也带来了挑战，特别是在指示支持某些特定选项时可能会无意中暴露STA的信息。

一个潜在的解决办法是创建一种关联状态，在这种状态下，STA可以连接到多个AP，并在决定加入哪个AP之前安全地协商额外参数。此外，随着802.11be/Wi-Fi 7多链路操作（MLO）的到来，STA有能力与一个AP建立两个链接，这就需要对多链路协商结构进行修改。例如，可以在协商过程中实施修改，确保第二链路参数通过加密帧交换，从而有效缓解多链

表 V
802.11BH TG研究挑战

主题	讨论	相关研究挑战
标识符格式	基于MAC地址的方案由于其简单性而吸引人，而不透明标识符需要定义允许设备在预关联方案中通信其DID的机制。通用标识符可以匹配每个场景的要求（例如，物联网、酒店）。	- 在定义防止标识符重用的有效方法。 - 开发系统以实现在运行时替换MAC地址。 - 优化低级驱动程序，以便快速交换标识符。 - 设计算法以实现高效的DID（分布式标识符）生成，并能抵御逆向工程攻击。
基于IE的方案	基于IE的方案可以缓解一些实施上的困难，但引入了兼容性和安全风险。例如，IE的存在可能无意中帮助概率引擎将参数与已知的MAC地址关联起来。	- 仔细设计信息元素，以适应多样化的场景并防止由于格式错误的字符串引发的安全威胁。 - 解决在非PMF（保护管理帧）网络中依赖PMF的IE方案的兼容性问题。 - 定义可扩展且高效的智能值编码或加密方法，用于IE的数据结构。
复杂性	实施复杂算法可能导致现实生活中的实现不理想。更简单且显而易见的方案可能提供更好的长期采用和实现效果。	- 为与新STA安全共享网络参数探索用户友好型解决方案。 - 确保网络安全与隐私不需要依赖于用户行为。
信任委托	设计标识符生成过程需要谨慎考虑，以防止损害RCM（随机化MAC地址）的目的。由AP（接入点）生成的标识符由于为每个STA（站点）生成唯一的标识符而增加了隐私保护。让STAs（站点）自己生成值可以避免延迟，但这可能导致身份冲突和AP识别挑战。	- 调查异构场景中的兼容性问题（例如，有和没有PMF（保护管理帧）的情况，STA是否接受特殊字符）。 - 设计分布式标识符生成机制，使身份冲突的问题几乎可以忽略不计。 - 为AP和STA定义安全的标识符生成算法，防止逆向工程攻击。
预关联发现	支持者认为，在特定网络中，某些使用场景，例如在关联之前将设备引导到特定频段或无线电信道，是至关重要的。这可以优化网络性能、减少拥堵并提高用户体验。反对者则强调了仅使用MAC地址执行某些操作所带来的风险和潜在的不安全行为。	- 处理带有PMF（保护管理帧）的“到达MAC”问题，并对使用MAC地址执行某些操作的固有风险进行详细分析。 - 研究新方案时考虑功能性和潜在安全影响之间的权衡。 - 确保符合802.11标准。

路场景带来的挑战。

确保当前（重新）关联阶段的保密性和真实性对于防止未经授权的访问和潜在的冒充攻击至关重要。为了达到这些目标，一种有效的做法是在认证阶段纳入802.1X/EAP交换以进行相互认证和密钥导出。通过采用这种增强措施，在（重新）关联阶段之前生成加密密钥，增强了整个过程的安全性。这一转变具有双重目的：首先，它使认证和关联交换的编排现代化，解决了过时的做法并与当代安全标准保持一致；其次，通过降低第三方尝试通过AP冒充收集STA参数的风险，强化了整体安全态势。

帧头中特定元素的暴露引起了STA的隐私担忧。为解决这一问题，对诸如源地址（SA）、目的地址（DA）和帧控制等敏感元素进行加密或混淆可以有效保护STA的隐私。通过实施这些措施，关键信息的保密

性得以维持，潜在的隐私风险得以缓解。然而，对帧头进行此类修改可能会遇到与现有系统的向后兼容性障碍。确保与旧设备和协议的无缝互操作性对于保持一个连贯且功能齐全的网络环境至关重要。因此，可以探索如在STA-AP对之外混淆地址等更简单的替代方案。这些方法在隐私保护与兼容性之间提供了折衷，使得可以在不影响网络整体功能的情况下实施有效的隐私措施。

确保某些管理帧的隐私对于防止STA的敏感信息泄露至关重要。通过保护这些帧免受未经授权的访问，可以降低信息泄露的风险并保护STA的隐私。IEEE已经认识到这一问题的重要性，并确定了应加密的十个具体管理帧以增强网络内的隐私和安全。此外，重要的是要承认通常被视为BPE的AP同样需要隐私保护。调整信标消息以传达基本信息或加密消息中的非平凡部分可

表 VI
802.11BH TG研究挑战

主题	讨论	相关研究挑战
做法	在实施隐私措施的同时保留“旧的”802.11做法是不简单的.CPE与BPE两种模式有效地解决了挑战.	在不中断802.11网络的情况下,设计有效地隐私保护机制.定义新的,平衡隐私需求与STA与AP的协商需要.
混淆与模式识别	使用混淆元素构建新的模式是有效的,但是模式识别技术能够揭露对话中的特定方面,这对完全隐私造成了挑战.	发展健壮可以抵御模式识别攻击的混淆技术.探索填充负载和空负载技术来进一步混淆内容并且防止信息泄露.
标准限制	允许网络所有者为新的STA打开AP通话引起了关于用户负担与科技设计问题的单眼.我们的目标是创建一个无需用户复杂工作便可“正常工作”的网络.	为与新STA安全共享网络参数探索用户友好型解决方案.确保网络安全与隐私不需要依赖于用户行为.
向后兼容性	混合网络中BPE与CPE模式的共存带来了在避免PII或PCI在遗留场景中暴露的情况下保护隐私的挑战.	设计无需在混合中牺牲隐私的向后兼容技术.研究在不同网络环境中保护PII与PCI的方法.
不同用户场景	解决802.11bi中各种不同的案例,包括呼和网络,复杂性,采用过程延长以及管理异常的挑战.	确定适用于不同机制的隐私保护机制.在确保复杂性和可伸缩性的前提下为多种场景设计隐私解决方案.

以大大有助于保护AP的隐私。基于返回客户端和新客户端之间的区别定制保护措施可能是必要的，以应对独特的使用案例并确保对隐私敏感信息的充分保护。

此外，为了对抗可能的指纹识别尝试并保护私人网络资产的身份和位置，建议定期更改AP的MAC地址。这种做法可以有效地阻止跟踪AP的尝试，并提升整个网络的隐私性。

MADINAS: IETF MADINAS工作组的主要目标是在无线网络中应对RCM带来的挑战，发布三个关键领域的建议。这些领域包括：

- 受影响的高层服务的识别：该小组旨在识别受RCM影响的高层服务，特别是那些在IETF RFC、最佳实践或其他IETF文档中描述的服务。通过对这些服务上的RCM影响进行综合检查，小组寻求了解具体的挑战，并致力于设计适当的解决方案来解决这些问题。
- 替代STA标识符的可行性评估：目标是评估在已识别的高层服务背景下采用STA替代标识符的可行性。这涉及到探索用更保护隐私和高效的识别机制替换MAC地址的可能性，从而消除对RCM缓解措施的需求。所提议替代方案的实用性、安全性和兼容性方面将被仔细考虑。
- 无需STA识别的服务提供的调查：小组将研究在无需STA识别的情况下提供某些服务的可能性。对于不需要MAC地址进行识别的情况，MADINAS旨在

识别以隐私友好的方式提供这些服务的机会。通过消除不必要的识别，小组寻求在保持基本网络功能的同时增强隐私实践。

在IETF MADINAS工作组的初期工作中，已经确定了一系列研究挑战，总结在表VII中。主要的研究挑战之一是庞大的IETF RFC集合，包含超过9000份文档。这个巨大的资料库需要细致的分类以识别有关RCM对各种服务的影响的相关信息。这项任务的耗时性质对该小组全面解决无线网络中的隐私问题构成了重大障碍。

此外，遇到的服务表现出多样化的特性，增加了实施一致隐私措施的复杂性。一个说明这种复杂性的例子是DHCP，它严重依赖于MAC地址进行操作。由RCM导致的频繁MAC地址变更可能会引起多个问题，如DHCP池耗尽、与隐私目标的冲突以及有效管理DHCP租约期限的挑战。

MADINAS小组已经识别出在不同领域运行的众多协议，每个都因为其设计早于RCM的出现而面临挑战。这些协议需要一种彻底且谨慎的方法来处理由RCM应用带来的复杂性。

尽管面临挑战，MADINAS小组仍然坚定地致力于提供全面的建议。这些预期会对网络实践产生深远影响，解决与RCM相关的隐私问题，并为更加注重隐私保护的无线网络奠定基础。然而，预计这些建议的采纳将是一个漫长的过程。所提出的更改意义重大，可能需要修改现有的网络协议、设备和基础设施。在整个行业

表 VII
IETF MADINAS WG 研究挑战

主题	讨论	相关研究挑战
梳理广泛的RFCs	超过9000的RFC需要被检查与分类.	定义有效的分类方法来分类信息.
服务的多样性	不同的服务在应用一致的隐私措施方面存在挑战.	为不同的服务和环境定制隐私.
DHCP租期管理	DHCP在设计时并未考虑RCM,这导致了在频繁MAC地址管理中的挑战.缩短租期持续时间可能会导致新的复杂性,如电池供电的客户机与服务器过载问题.	为多样化的服务和环境设计定制的隐私解决方案.开发机制以使DHCP服务器能够有效应对与RCM（随机化MAC地址）相关的挑战.
DHCP服务池耗尽	允频繁的MAC地址变化会导致DHCP过载,耗尽可用地址.	定义防止地址池耗尽的解决方案.设计高效的IP地址分配方案.
与隐私目标的冲突	DHCP设置,如客户标识符,可能与RCM隐私目标有冲突,对准确识别客户端带来挑战.	确定合适的隐私保护机制以平衡客户认证与RCM隐私.
综合性方法	解决RCM影响下的多种协议导致的复杂问题需要一个综合且细致的解决方案.	定义同意的隐私框架,集成不同的隐私协议并且与RCM目标保持一致.

内以标准化和互操作的方式实施这些更改需要利益相关者之间的仔细考虑、测试和协作。随着这些建议的扎根并获得接受，它们有可能建立一个新的网络实践景观，为用户提供更大的隐私控制权，同时访问无线服务。

X. 结论

本教程深入探讨了IEEE 802.11通信中的隐私问题和RCM（随机化MAC地址）的使用。随着个人设备的普及，一个以效率为中心的协议引入了漏洞，允许攻击者识别站点并危及用户隐私。为解决这个问题，厂商已经融入了RCM，但由于其对通信的影响，促使标准机构着手处理与RCM相关的问题。

IEEE 802.11aq指南提倡使用不变的MAC地址以保持关联一致性，但动态断开连接允许符合规范但经过修改的MAC地址。即使在遵循802.11aq指南的情况下，RCM也会扰乱依赖静态MAC的功能。IEEE 802.11bh旨在创建一种替代标识符，在保护用户隐私的同时使AP能够识别。为了克服RCM对策而提出的去随机化技术同时激发了IEEE 802.11bi的诞生，目标是编纂潜在隐私漏洞的详尽列表以及更加私密的IEEE 802.11标准的前提条件。这项活动致力于开发超越单纯MAC地址随机化的更广泛的WLAN隐私增强框架。

由于MAC地址也服务于高层服务，IETF MADINAS工作组仔细审查了RCM对这些服务的影响，旨在提供关于MAC和站点标识符使用的最佳实践。这一努力试图改进这些服务，使其适应RCM和用户隐私需求。尽管取得了这些进展，这些倡议的实现可能需要数年时间。在此期间，站点供应商增强用户隐私的动力依然

存在，希望行业能在专有方案获得牵引力之前创新解决方案，以免影响共存和互操作性。这一努力对于维护用户的安全无缝Wi-Fi体验至关重要。

教程概述了所获得的见解，并对分析的标准制定小组最初的尝试进行了详尽分析。此外，还全面调查了显著的研究挑战。本教程的总体目标是激励研究社区参与探索提供新颖方法和创新解决方案，从而通过标准化努力为持续推动增强WLAN隐私做出重大贡献。